Université de Yaoundé I ů Département d'Informatique ů LIMSI

COURS UNIVERSITAIRE

Audit des Systèmes d'Information

Fondements, Méthodes, Référentiels et Pratique

☞ Cas fil rouge : Entreprise LiZbiZ

✌ COSO ů COBIT ů ISO 27001 ů ISO 19011

➤ Audit fonctionnel ů Audit de sécurité ů Gouvernance IA

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA ů CISM ů CGEIT ů CRISC ů CDPSE

Chercheur — LIMSI, Université de Yaoundé I

Expert Judiciaire — Cadre supérieur, Contrôle Supérieur de l'État — Consultant International

Année académique 2025–2026

Audit des Systèmes d'Information

Fondements, Méthodes, Référentiels et Pratique

Auteur : MINKA MI NGUIDJOÏ Thierry Emmanuel
Institution : Université de Yaoundé I — LIMSI
Année : 2025–2026

Ce document est un support de cours universitaire rédigé à des fins pédagogiques. Toute reproduction partielle ou totale à des fins commerciales est interdite sans l'autorisation écrite de l'auteur. Les références à des produits, organisations ou normes sont citées à titre pédagogique uniquement.

Les certifications CISA, CISM, CGEIT, CRISC et CDPSE sont des marques déposées de l'**ISACA** (*Information Systems Audit and Control Association*).

Contact : Université de Yaoundé I, Département d'Informatique, Yaoundé, Cameroun.

ń Éduquer, c'est donner à l'autre les armes de sa propre lucidité. ż

À ceux qui ont pris la peine de comprendre
avant d'agir, et de vérifier avant de conclure.

Et à tous les auditeurs en devenir
qui liront ces pages avec l'exigence
qu'ils apporteront demain à leur métier.

REMERCIEMENTS

La conception de ce cours a bénéficié de l'expérience conjointe du chercheur et du praticien. L'auteur exprime sa reconnaissance à **tous les relecteurs anonymes et non** et qui ont contribué à l'enrichissement de cette version. Une mention spéciale pour **le Professeur Hamadou Bâ** Directeur Général de l'Hôpital Général de Garoua, pour son amitié qui nous a permis de confronter plusieurs de nos idées ici développées avec la réalité de la structure exigeante dont il a lacharge. De même, le Directeur du Contrôle Budgétaire au ministère des finances, **Madame Tabenyang Augusta épouse Ndjock Arrey**, a été d'un appui significatif dans la rédactionde ce cours, son professionalisme et sa disponiblité forcent l'admiration.

La matière de ce cours a été nourrie par les missions menées au sein des **Services du Contrôle Supérieur de l'État**, où l'audit n'est pas une abstraction académique mais une responsabilité institutionnelle quotidienne. De même des prestations comme consultant individuel auprès d'entreprises nationales et internationales, ce qui lui donne une dimension transnationale.

Enfin, ce cours n'aurait pas existé sans les étudiants qui, par leurs questions, leurs doutes et leur curiosité, en ont constamment éprouvé la clarté et la pertinence. Qu'ils en soient remerciés.

TABLE DES MATIÈRES

Remerciements **5**

Liste des figures **13**

Liste des tableaux **15**

Liste des codes source **17**

Introduction Générale **1**

I Fondements Théoriques et Méthodologiques **5**

1 Cas Pratique Fil Rouge : Entreprise LiZbiZ **7**

1.1 Identité et Contexte de l'Entreprise . . . 7

1.1.1 Présentation Générale . . . 7

1.1.2 Contexte Stratégique et Enjeux . . . 7

1.2 Le Système d'Information : Périmètre de l'Audit . . . 8

1.2.1 L'Application "APPLICATION" . . . 8

1.2.2 Architecture Technique (Simplifiée) . . . 8

1.3 Le Mandat d'Audit . . . 8

1.3.1 Origine de la Mission . . . 8

1.3.2 Objectifs de la Mission . . . 8

1.3.3 Organisation de l'Équipe (RACI) . . . 9

1.4 Environnement de Laboratoire (Immersion) . . . 9

1.4.1 Travaux Pratiques Préparatoires . . . 9

2 Définitions, Concepts et Bases de l'Audit et du Contrôle **11**

2.1 Audit et Contrôle : Distinction Fondamentale . . . 11

2.1.1 Définitions . . . 11

2.1.2 Comparaison . . . 11

2.2 L'Assurance Raisonnable . . . 12

2.3 Le Concept de Risque . . . 12

2.3.1 Définition Académique . . . 12

2.3.2 Le Cycle du Risque . . . 12

2.4 Le Contrôle Interne (CI) . . . 12

2.4.1 Définition . . . 13

2.4.2 Les Types de Contrôles . . . 13

2.5 Principes d'Organisation du Contrôle . . . 13
2.5.1 La Règle des Quatre Yeux (Four Eyes Principle) . . . 13
2.5.2 L'Allégorie des Deux Mains . . . 13
2.6 La Boîte à Outils de l'Auditeur : Le Vocabulaire de la Mission . . . 14
2.6.1 Le "Contradictoire" . . . 14
2.6.2 Observation vs Constatation . . . 14
2.6.3 Sur place et Sur pièces . . . 14
2.7 Définitions des Systèmes d'Information (SI) . . . 14
2.7.1 Système Informatique vs Système d'Information . . . 15
2.7.2 Composantes Techniques (Rappels) . . . 15

3 Démarche Générale d'Audit des Systèmes d'Information 17

3.1 Le Cadre Normatif et Déontologique de la Mission . . . 17
3.1.1 La Référence Absolue : ISO 19011 . . . 17
3.1.1.1 Les Principes de l'Audit (Comportement de l'Auditeur) . . . 17
3.1.2 Le Référentiel IFACI (IIA) : La Charte d'Audit . . . 17
3.2 Phase 1 : Travaux Préparatoires et Planification . . . 17
3.2.1 Documents à Solliciter (Prise de Connaissance) . . . 17
3.2.2 Analyse Préalable des Risques . . . 18
3.2.3 Identification des Ressources . . . 18
3.2.4 Le Rapport d'Orientation (ou Plan de Mission) . . . 19
3.3 Phase 2 : Exécution de la Mission (Le Terrain) . . . 19
3.3.1 Réunion d'Ouverture (Kick-off Meeting) . . . 19
3.3.2 Techniques de Collecte d'Information . . . 19
3.3.2.1 Les Entretiens . . . 19
3.3.2.2 L'Observation . . . 19
3.3.2.3 Les Tests Techniques et Analyse de Données . . . 20
3.3.3 Consignation des Faits (Les Papiers de Travail) . . . 20
3.4 Phase 3 : Communication des Résultats . . . 20
3.4.1 Le Projet d'Observation . . . 20
3.4.2 Le Contradictoire (Validation) . . . 20
3.4.3 Le Rapport Final . . . 21
3.4.4 Réunion de Clôture . . . 21
3.5 Phase 4 : Suivi de la Mission . . . 21
3.5.1 Le Plan d'Action . . . 21
3.5.2 Le Suivi (Follow-up) . . . 21
3.6 Le Dossier d'Audit : Structure et Traçabilité . . . 21
3.7 La Matrice des Risques : Priorisation des Travaux . . . 21
3.8 Workflow Séquentiel de la Mission . . . 22

II Référentiels et Typologies d'Audit 23

4 Normes et Référentiels Usuels en Audit des Systèmes d'Information 25

4.1 COSO : Le Modèle de Contrôle Interne . . . 25
4.1.1 Présentation . . . 25
4.1.2 Les Trois Objectifs . . . 25
4.1.3 Les Cinq Composantes (Le Cube COSO) . . . 25
4.2 COBIT : La Gouvernance des SI . . . 26
4.2.1 Présentation . . . 26
4.2.2 Objectifs et Apports . . . 26
4.2.3 Structure de COBIT (Version 5 / 2019) . . . 26
4.2.4 Utilisation par l'Auditeur . . . 26
4.2.5 La Cascade d'Objectifs COBIT . . . 26
4.3 La Série ISO 27000 : La Sécurité Normative . . . 27
4.3.1 Vue d'Ensemble . . . 27
4.3.2 Importance pour l'Audit . . . 27
4.4 Synthèse : Comment Choisir ? . . . 28

5 Principaux Types d'Audit dans les Systèmes d'Information 29

5.1 Audit des Applications en Service . . . 29
5.1.1 Objectifs . . . 29
5.1.2 Les Deux Dimensions de l'Audit . . . 29
5.2 Audit de la Fonction Informatique (DSI) . . . 30
5.2.1 Objectifs . . . 30
5.2.2 Points de Contrôle Typiques . . . 30
5.3 Audit des Projets Informatiques . . . 30
5.3.1 Objectifs . . . 30
5.3.2 Phases Clés à Auditer . . . 30
5.4 Audit de Sécurité Informatique . . . 31
5.4.1 Objectifs . . . 31
5.4.2 Les Piliers de la Sécurité (D.I.C.T.) . . . 31
5.4.3 Méthodologie Technique . . . 31
5.5 Autres Types d'Audits . . . 31
5.5.1 Audit du Support Utilisateur et Gestion du Parc . . . 31
5.5.2 Audit de la Fonction Étude (Développement) . . . 31
5.6 Audit de la Continuité d'Activité et de la Résilience . . . 31
5.6.1 Concepts Clés de Résilience . . . 31
5.7 Audit des Tiers, du Cloud et de l'Outsourcing . . . 32
5.7.1 Le "Droit d'Audit" et les Rapports SOC . . . 32
5.8 Focus technique : Les Contrôles Applicatifs (IPO) . . . 32

6 Conception d'un Outil d'Aide à l'Audit des Systèmes d'Information 33

6.1 Pourquoi un outil structuré d'aide à l'audit ? . . . 33

6.1.1 Fonctions de l'outil . . . 33

6.1.2 Ancrage normatif . . . 34

6.2 La méthode de décomposition hiérarchique . . . 34

6.2.1 Vue d'ensemble de l'arborescence . . . 35

6.3 Rôle et logique de chaque palier . . . 36

6.3.1 Niveau 1. Le Domaine . . . 36

6.3.2 Niveau 2. Le Point de contrôle . . . 37

6.3.3 Niveau 3. L'Objectif de contrôle . . . 37

6.3.4 Niveau 4. Le Critère . . . 38

6.3.5 Niveau 5. L'Élément requis . . . 38

6.3.6 Niveau 6. La Question d'évaluation . . . 39

6.3.7 Niveau 7. Le Risque . . . 40

6.3.8 Niveau 8. La Conséquence . . . 41

6.4 Universalité et adaptabilité de la méthode . . . 41

6.5 Structuration du fichier Excel de l'outil d'aide à l'audit . . . 42

6.5.1 Architecture du classeur . . . 43

6.5.2 Structure de chaque feuille de domaine . . . 43

6.5.3 Fonctionnement des formules d'automatisation . . . 45

6.5.4 La feuille de synthèse . . . 46

6.6 Protocole de construction de l'outil pour un nouveau domaine . . . 47

6.6.1 Étape 1 : Délimiter le domaine . . . 47

6.6.2 Étape 2 : Identifier les points de contrôle . . . 47

6.6.3 Étape 3 : Décomposer chaque point en objectifs de contrôle . . . 48

6.6.4 Étape 4 : Dériver les critères . . . 48

6.6.5 Étape 5 : Spécifier les éléments requis et les questions . . . 48

6.6.6 Étape 6 : Formuler les risques et les conséquences . . . 48

6.6.7 Étape 7 : Saisir les formules d'automatisation et tester . . . 48

6.7 Le Tableau de Bord de Synthèse (Reporting) . . . 49

III Enjeux Contemporains et Évaluation 51

7 Sujets Connexes : IA et Fraude dans les SI 53

7.1 L'Intelligence Artificielle et l'Audit . . . 53

7.1.1 Le Rôle et l'Impact de l'IA dans les SI . . . 53

7.1.2 Les Risques Liés à l'IA . . . 53

7.1.3 Enjeux pour l'Auditeur . . . 53

7.2 La Fraude dans et par les Systèmes d'Information . . . 54

7.2.1 Nature de la Fraude Informatique . . . 54

7.2.2 L'Impact de la Fraude . . . 54

7.2.3 Les Parades (Dispositifs Anti-Fraude) 54
7.2.3.1 Contrôles Préventifs 54
7.2.3.2 Contrôles Détectifs 55
7.2.4 Le Cadre Réglementaire : L'IA Act et la Classification des Risques 55
7.3 L'Audit Forensics : De la Constatation à la Preuve Judiciaire 55
7.3.1 La Chaîne de Garde (Chain of Custody) 55
7.3.2 Principes de Saisie de Preuve Numérique 56
7.3.3 Schématisation : Le Triangle de la Fraude 56

8 Évaluation Finale du Cours 57

8.1 Partie A : QCM (Choix Multiples) 57
8.2 Partie B : Vrai ou Faux 61
8.3 Partie C : Questions Ouvertes 62
8.4 Partie D : Cas Pratique (Étude de Cas) 62
8.4.1 Scénario : Audit de l'Application "Comptabilité" de Lizbiz's 62

IV Travaux Pratiques Immersifs 65

9 Laboratoire 1 : Audit d'une Application en Service 67

9.1 Objectifs du TP 67
9.2 Étape 1 : Préparation de l'Environnement (Base de Données) 67
9.2.1 Création du Schéma Relationnel 67
9.2.2 Chargement des Données de Test 68
9.3 Étape 2 : Évaluation du Contrôle Interne (COSO) 69
9.3.1 Domaine : Environnement de Contrôle 69
9.3.2 Domaine : Activités de Contrôle (Séparation des Tâches) 69
9.4 Étape 3 : Audit des Données (Tests Substantifs) 69
9.4.1 Test d'Intégrité : Recherche de Doublons 69
9.4.2 Test de Cohérence : Equilibre Journal 69
9.4.3 Test de Convention : Seuil de Validation 70
9.5 Étape 4 : Rapport d'Audit 70
9.5.1 Rédaction des Observations 70
9.6 Livrables à rendre 70

10 Laboratoire 2 : Audit de Sécurité d'une Infrastructure 71

10.1 Objectifs du TP 71
10.2 Étape 1 : Analyse de l'Architecture (Revue Documentaire) 71
10.2.1 Présentation de l'Infrastructure LiZbiZ 71
10.2.2 Travail Demandé : Analyse de la Cartographie 71
10.3 Étape 2 : Découverte et Cartographie Réelle (Nmap) 72
10.3.1 Scan de Découverte 72

10.3.2 Questions d'Audit 72
10.4 Étape 3 : Audit de Configuration et Vulnérabilités 72
10.4.1 Test de Segmentation (Bypass Pare-feu) 72
10.4.2 Scan de Vulnérabilités (OpenVAS / Nessus) 72
10.5 Étape 4 : Analyse des Configurations (Hardening) 73
10.5.1 Audit des Comptes par Défaut 73
10.5.2 Audit des Protocoles 73
10.6 Étape 5 : Rapport d'Audit Technique 73
10.6.1 Synthèse des Risques 73
10.6.2 Plan de Remédiation 73
10.7 Livrables à Rendre 73

Conclusion Générale **75**

Index **79**

TABLE DES FIGURES

6.1 Arborescence de la méthode de décomposition hiérarchique 36

LISTE DES TABLEAUX

1.1 Équipe d'audit et interlocuteurs 9

2.1 Différences entre Audit et Contrôle 11
2.2 Vocabulaire de la mission d'audit 14

3.1 Les 6 principes de l'audit selon ISO 19011 18
3.2 Matrice de criticité (Heatmap) pour le plan de test 22

4.1 Les 5 composantes du référentiel COSO 26
4.2 Les domaines de COBIT 27
4.3 Comparatif des référentiels 28
4.4 Tableau comparatif des référentiels d'audit 28

5.1 Matrice de contrôle applicatif IPO 32

6.1 Invariance structurelle : le même niveau pour trois domaines différents 42
6.2 Structure standard d'une feuille de domaine dans l'outil d'aide à l'audit . . . 44

9.1 Modèle de fiche d'observation 70

10.1 Grille de vérification des protocoles 73

LISTINGS

9.1 Script de création de la base APPLICATION 67
9.2 Exemple d'insertion 68
10.1 Scan réseau Nmap 72

INTRODUCTION GÉNÉRALE

« L'audit n'est pas une sanction. C'est un regard lucide posé sur une organisation qui veut progresser. »
— Architecte de l'Ombre

Contexte et Pertinence du Cours

L'ère numérique a profondément reconfiguré l'architecture des organisations modernes. Les systèmes d'information ne constituent plus de simples supports opérationnels : ils sont devenus le substrat vital sur lequel reposent la compétitivité, la conformité réglementaire et la souveraineté stratégique des entreprises et institutions. Dès lors, la question de leur maîtrise, de leur fiabilité et de leur sécurité s'impose comme une priorité absolue de gouvernance.

C'est précisément dans cet espace de tension entre performance opérationnelle et impératif de contrôle que s'inscrit la discipline de l'**audit des systèmes d'information**. Loin d'être une activité ancillaire, l'audit SI constitue aujourd'hui une fonction stratégique à part entière, exercée par des professionnels certifiés — CISA, CISM, CRISC — dont l'autorité repose autant sur leur indépendance que sur leur rigueur méthodologique.

Ce cours s'adresse à des étudiants qui seront demain auditeurs, responsables sécurité, consultants en gouvernance informatique ou décideurs numériques. Il leur offre les fondements conceptuels, les outils méthodologiques et la maturité pratique nécessaires pour conduire une mission d'audit avec professionnalisme.

Fil Conducteur : L'Entreprise LiZbiZ

L'ensemble de ce cours est structuré autour d'un cas pratique unique et cohérent : l'entreprise fictive **LiZbiZ**, acteur du commerce électronique en pleine transformation digitale. Ce choix pédagogique délibéré permet d'ancrer chaque concept théorique dans une situation concrète, d'observer les mêmes risques sous plusieurs angles d'audit, et de simuler l'expérience complète d'une mission.

Au fil des chapitres, vous endosserez successivement le rôle d'auditeur junior, senior et de chef de mission, confrontés à des problèmes réels : fraude aux fournisseurs fictifs, failles de sécurité réseau, conformité RGPD, gouvernance des projets IA.

Objectifs Généraux du Cours

✦ Objectifs du chapitre

À l'issue de ce cours, l'étudiant sera capable de :

1. **Maîtriser le vocabulaire professionnel** de l'audit et du contrôle interne.
2. **Appliquer la démarche d'audit** (planification, exécution, rapport) selon les normes ISO 19011 et ISACA.
3. **Mobiliser les référentiels** COSO, COBIT et ISO 27001 comme grilles d'évaluation.
4. **Identifier et cartographier les risques** SI dans un contexte organisationnel donné.
5. **Conduire des tests d'audit** techniques (SQL, réseau, analyse de configuration).
6. **Rédiger un rapport d'audit** structuré, communicable à une direction générale.
7. **Aborder les enjeux émergents** : intelligence artificielle, fraude numérique, protection des données.

Organisation du Cours

Le cours est organisé en deux grandes parties, précédées d'un ancrage contextuel et suivies de travaux pratiques immersifs.

Partie I — Fondements théoriques et méthodologiques

Cette partie établit les concepts structurants indispensables à toute démarche d'audit. Elle couvre les définitions fondamentales (Chapitre **??**), la démarche générale d'audit SI (Chapitre **??**), les normes et référentiels reconnus (Chapitres **??** et **??**), ainsi que les principaux types d'audits rencontrés en milieu professionnel (Chapitre **??**).

Partie II — Domaines spécialisés et enjeux contemporains

Cette partie approfondit les domaines de l'audit technique (Chapitre **??**), et présente l'évaluation finale de synthèse (Chapitre **??**), qui mobilise l'ensemble des acquis dans le contexte LiZbiZ.

Travaux pratiques (TP)

Deux laboratoires immersifs complètent le dispositif théorique : un audit fonctionnel de l'application de gestion (TP 1) et un audit de sécurité d'infrastructure réseau (TP 2).

Posture Épistémologique et Déontologie

L'auditeur n'est ni un juge ni un censeur. Il est un professionnel au service de la vérité organisationnelle — une vérité que ni la complaisance ni la suspicion systématique ne peuvent servir. La déontologie de l'audit repose sur quatre piliers indissociables :

l'**intégrité**, l'**objectivité**, la **confidentialité** et la **compétence**. Ces valeurs, portées par l'ISACA (*Information Systems Audit and Control Association*)et l'IIA (*Institute of Internal Auditors*), irrigueront l'ensemble de notre démarche pédagogique.

Note

Prérequis recommandés :

- Bases de la sécurité informatique et des réseaux.
- Notions de bases de données relationnelles (SQL).
- Culture générale de la gouvernance d'entreprise.
- Capacité à lire et analyser des documents techniques en français et en anglais.

Ce cours a été conçu et rédigé avec rigueur pour servir la formation des auditeurs de demain. Bonne lecture, et bon audit.

MINKA MI NGUIDJOÏ Thierry Emmanuel

partie I

Fondements Théoriques et Méthodologiques

1

CAS PRATIQUE FIL ROUGE : ENTREPRISE LIZBIZ

Ce chapitre présente le contexte de l'entreprise **LiZbiZ**, qui servira de support unique pour l'ensemble des travaux pratiques et mises en situation de ce cours.

1.1 Identité et Contexte de l'Entreprise

1.1.1 Présentation Générale

LiZbiZ est une entreprise commerciale spécialisée dans la vente de matériel informatique et high-tech. Elle s'est distinguée par une digitalisation rapide de ses processus, passant d'un modèle traditionnel à un modèle hybride fort sur le e-commerce.

- **Secteur :** Commerce de gros et de détail / E-commerce.
- **Effectif :** 150 salariés.
- **Activité principale :** Vente de matériels, gestion de commandes en ligne, logistique associée.

1.1.2 Contexte Stratégique et Enjeux

L'entreprise traverse une phase critique de transformation.

1. **Transformation Digitale :** LiZbiZ a récemment intégré des solutions d'Intelligence Artificielle (IA) pour optimiser sa logistique et son service client (Chatbots, prévision de stocks).
2. **Exposition Médiatique :** L'entreprise est sous le feu des projecteurs. Des rumeurs de fraudes internes et de dysfonctionnements informatiques commencent à circuler.
3. **Enjeu Réglementaire :** En tant qu'acteur majeur du e-commerce, LiZbiZ est soumise au RGPD et doit assurer la protection des données clients.

Cas Pratique — Entreprise LiZbiZ

Situation déclenchante : Suite à plusieurs articles de presse évoquant une possible fraude financière assistée par des failles informatiques et une utilisation contestable de l'IA, le Comité de Direction (COMEX) a décidé de mandat un audit approfondi pour rassurer les actionnaires.

1.2 Le Système d'Information : Périmètre de l'Audit

Le Système d'Information de LiZbiZ est centré autour d'une application majeure, simplement nommée **APPLICATION**, qui gère l'ensemble du cycle de vie de l'entreprise.

1.2.1 L'Application "APPLICATION"

C'est le cœur numérique de l'entreprise. Elle assure les fonctions vitales suivantes :

- **Gestion Commerciale :** Création des comptes clients/fournisseurs, gestion des commandes.
- **Gestion Comptable :** Saisie des écritures, plan comptable, tenue des journaux.
- **Gestion Financière :** Facturation, suivi de la trésorerie, gestion des immobilisations.
- **Reporting :** Génération des états financiers et rapports de synthèse.

1.2.2 Architecture Technique (Simplifiée)

L'infrastructure repose sur une architecture cliente-serveur :

- **Serveur de Base de Données :** SGBD Relationnel (PostgreSQL) hébergeant les données critiques.
- **Serveur d'Application :** Interface utilisateur et traitement métier.
- **Postes Clients :** Accès via navigateur web ou client lourd (comptabilité).

1.3 Le Mandat d'Audit

Cette section définit le cadre contractuel de votre mission en tant qu'auditeur.

1.3.1 Origine de la Mission

La mission fait suite à une demande formelle du COMEX, motivée par :

1. La nécessité de vérifier la fiabilité des informations financières produites par l'APPLICATION.
2. Le besoin de sécuriser le nouveau périmètre IA.
3. La volonté de détecter d'éventuelles fraudes internes (Section 5.2 du cours).

1.3.2 Objectifs de la Mission

L'objectif général est de réaliser un **Audit d'une Application en Service**. Les objectifs spécifiques sont :

- **Fiabilité :** S'assurer que les données comptables sont exactes et complètes.
- **Sécurité :** Vérifier que les mécanismes de contrôle d'accès sont efficaces.
- **Conformité :** S'assurer du respect des procédures internes et des lois (RGPD).

Rôle	Responsabilité	Interlocuteur LiZbiZ
Chef de Mission	Supervision, Synthèse, Rapport	DSI / DG
Auditeur Senior	Tests techniques, Entretiens	Responsable Informatique
Auditeur Junior	Saisie, Extraction données	Utilisateurs clés

Table 1.1: Équipe d'audit et interlocuteurs

1.3.3 Organisation de l'Équipe (RACI)

L'équipe de mission est composée comme suit :

1.4 Environnement de Laboratoire (Immersion)

Pour mener cette mission, nous disposerons d'un environnement simulé représentant le SI de LiZbiZ.

1.4.1 Travaux Pratiques Préparatoires

Dans le cadre de ce cours, vous serez amenés à :

1. **Créer l'environnement :** Mettre en place la base de données de l'APPLICATION (Schéma relationnel fourni).
2. **Charger les données :** Peupler la base avec un jeu de données réalistes (Clients, Factures, Écritures).
3. **Concevoir les outils :** Développer des requêtes SQL et des feuilles de calcul pour automatiser les tests d'audit.

★ Attention

Mise en garde professionnelle : L'auditeur ne doit jamais intervenir sur le système de production réel sans précautions. L'utilisation d'un laboratoire ou d'une copie (snapshot) est impérative pour ne pas perturber l'activité de LiZbiZ.

2

DÉFINITIONS, CONCEPTS ET BASES DE L'AUDIT ET DU CONTRÔLE

Ce chapitre établit le vocabulaire commun de l'auditeur. Une ambiguïté sur les termes "contrôle", "risque" ou "objectif" peut compromettre la compréhension de toute la mission.

2.1 Audit et Contrôle : Distinction Fondamentale

Il est fréquent de confondre ces deux notions, pourtant distinctes.

2.1.1 Définitions

Définition

L'Audit : Activité d'examen d'un **processus** ou d'une organisation par un tiers indépendant, visant à évaluer la conformité, l'efficacité et l'optimisation.

Définition

Le Contrôle : Action de vérification ponctuelle d'une **opération** pour s'assurer de sa régularité, exactitude ou sincérité.

2.1.2 Comparaison

Critère	Audit	Contrôle
Sujet	Un processus global.	Une opération unitaire.
But	Amélioration, Optimisation.	Vérification, Conformité.
Acteur	Indépendant (Interne ou Externe).	Souvent opérationnel.
Périodicité	Ponctuelle (Mission).	Continue ou fréquente.

Table 2.1: Différences entre Audit et Contrôle

Cas Pratique — Entreprise LiZbiZ

Exemple Lizbiz's :

- **Contrôle :** Le comptable vérifie que le montant d'une facture correspond à la commande reçue.

➢ **Audit :** L'auditeur analyse l'ensemble du processus "Achat-Fournisseur" pour voir si les contrôles (comme celui du comptable) sont efficaces et appliqués tout le temps.

2.2 L'Assurance Raisonnable

Définition

Assurance Raisonnable : Niveau de confiance élevé, mais non absolu, que l'auditeur apporte sur la fiabilité des éléments analysés.

L'auditeur ne peut pas garantir à 100% qu'il n'y a pas d'erreur ou de fraude (limite intrinsèque de l'échantillonnage, limites du temps, dissimulation possible). La certification ISO n'est pas une assurance "tous risques".

2.3 Le Concept de Risque

L'audit est intrinsèquement lié à la gestion des risques.

2.3.1 Définition Académique

Le risque est la probabilité qu'une menace exploite une vulnérabilité pour générer un impact sur une ressource.

$$Risque = Probabilit \times Impact$$

2.3.2 Le Cycle du Risque

L'auditeur intervient souvent sur le "Risque Résiduel".

1. **Risque Inhérent :** Risque brut, sans aucune mesure de protection.
2. **Mesures de Contrôle :** Ce que l'entreprise a mis en place (Prévention, Détection).
3. **Risque Résiduel :** Risque qui reste après application des contrôles. C'est celui que l'auditeur évalue.

Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : Le **Risque Inhérent** de fraude à la commande est élevé. Lizbiz's a mis en place un **Contrôle** de validation manuelle par le manager. L'auditeur vérifie si ce contrôle fonctionne bien. Si le manager valide tout sans regarder, le **Risque Résiduel** reste élevé.

2.4 Le Contrôle Interne (CI)

2.4.1 Définition

Définition

Contrôle Interne : Ensemble des mesures prises par une organisation pour maîtriser ses activités et atteindre ses objectifs (Performance, Sécurité, Conformité).

2.4.2 Les Types de Contrôles

On distingue généralement trois catégories de contrôles :

1. **Préventifs :** Visent à empêcher l'erreur ou la fraude (ex: Mot de passe, Séparation des tâches).
2. **Détectifs :** Visent à identifier l'erreur lorsqu'elle s'est produite (ex: Relevé de banque, Logs, Alarmes).
3. **Correctifs :** Visent à corriger l'erreur et rétablir la situation (ex: Procédure de rejet de facture, Restauration de sauvegarde).

2.5 Principes d'Organisation du Contrôle

Deux principes classiques régissent l'organisation du contrôle interne.

2.5.1 La Règle des Quatre Yeux (Four Eyes Principle)

Définition

Principe selon lequel toute décision ou opération sensible doit être validée par **deux personnes distinctes** et compétentes.

Cela empêche une seule personne de détourner des fonds ou de valider ses propres erreurs.

2.5.2 L'Allégorie des Deux Mains

Pour empêcher la fraude, il faut séparer les tâches conflictuelles :

- **Main Droite (Opérationnel) :** Celui qui exécute l'opération (ex: saisir la commande).
- **Main Gauche (Contrôle) :** Celui qui valide ou contrôle l'opération (ex: valider le paiement).

★ Attention

Danger : Si une même personne a le rôle "Créer Fournisseur" ET "Payer Fournisseur", le système est vulnérable à la fraude (création d'un fournisseur fictif). C'est une Non-Conformité majeure.

2.6 La Boîte à Outils de l'Auditeur : Le Vocabulaire de la Mission

Pour structurer ses travaux, l'auditeur utilise un vocabulaire précis pour décrire ce qu'il fait.

Terme	Définition
Point de Contrôle	Élément précis sur lequel porte l'audit (ex: Le serveur de paiement).
Objectif de Contrôle	But à atteindre (ex: Assurer la confidentialité des données).
Critère d'évaluation	La règle de référence (ex: La politique de sécurité, la norme ISO).
Question d'évaluation	La question technique posée pour vérifier le critère (ex: "Les flux sont-ils chiffrés ?").
Constatation	Le résultat factuel de l'audit (ex: "Les flux ne sont pas chiffrés").

Table 2.2: Vocabulaire de la mission d'audit

2.6.1 Le "Contradictoire"

Principe fondamental de l'audit : l'audité doit pouvoir s'expliquer et contester les faits avant la rédaction finale du rapport. L'auditeur ne peut pas porter de jugement sans avoir entendu l'audité.

2.6.2 Observation vs Constatation

- **Constatation :** Un fait brut noté lors de l'enquête (ex: "L'employé n'a pas verrouillé sa session").
- **Observation :** L'observation validée et documentée dans le rapport, avec analyse de l'impact.

2.6.3 Sur place et Sur pièces

Deux méthodes de vérification :

- **Sur place :** Présence physique de l'auditeur (entretiens, observation des locaux).
- **Sur pièces :** Analyse de documents à distance (revue de procédures, extraction de données).

2.7 Définitions des Systèmes d'Information (SI)

Pour auditer l'informatique, il faut en comprendre les composantes.

2.7.1 Système Informatique vs Système d'Information

Définition

- **Système d'Information (SI) :** Ensemble organisé de ressources (personnes, données, procédures) permettant de traiter l'information dans l'organisation.
- **Système Informatique :** Partie technique du SI (Matériel, Logiciel, Réseau).

L'auditeur audite le SI (le métier, l'usage) en s'appuyant sur la technique du Système Informatique.

2.7.2 Composantes Techniques (Rappels)

- **Système d'exploitation :** Interface entre matériel et logiciels (Windows, Linux).
- **Base de données :** Structuration des données (PostgreSQL, Oracle).
- **Réseau :** Liaison entre les équipements.
- **Sécurité :** Protection des actifs (Firewall, Antivirus).

3

DÉMARCHE GÉNÉRALE D'AUDIT DES SYSTÈMES D'INFORMATION

Ce chapitre détaille le processus complet d'une mission d'audit, de sa commande à la remise du rapport. Il s'appuie sur les standards internationaux (ISO 19011) pour garantir le professionnalisme de l'intervention.

3.1 Le Cadre Normatif et Déontologique de la Mission

Avant d'agir, l'auditeur doit connaître les règles du jeu.

3.1.1 La Référence Absolue : ISO 19011

La norme **ISO 19011** (Lignes directrices pour l'audit des systèmes de management) est la référence universelle. Elle définit **comment** auditer.

3.1.1.1 Les Principes de l'Audit (Comportement de l'Auditeur)

L'ISO 19011 définit 6 principes éthiques fondamentaux qui guident le comportement de l'auditeur avant, pendant et après la mission.

3.1.2 Le Référentiel IFACI (IIA) : La Charte d'Audit

Pour l'audit interne, le référentiel de l'**IFACI** (Institut Français de l'Audit et du Contrôle Internes) impose l'existence d'une **Charte d'Audit**.

Définition

Charte d'Audit : Document officiel qui définit le mandat de l'audit, son positionnement hiérarchique, ses pouvoirs d'investigation et l'étendue de ses compétences.

Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : Si le DSI refuse l'accès aux logs, l'auditeur invoque la **Charte d'Audit** signée par le PDG, stipulant que "l'audit a un accès illimité à tous les documents nécessaires". Sans cette charte, l'auditeur est désarmé.

3.2 Phase 1 : Travaux Préparatoires et Planification

C'est la phase "d'immersion". Elle conditionne le succès de la mission.

3.2.1 Documents à Solliciter (Prise de Connaissance)

L'auditeur ne part pas de zéro. Il demande les documents existants :

Principe	Définition	Application Lizbiz's
Intégrité	Être honnête, responsable et éthique.	L'auditeur ne cache pas les problèmes techniques détectés, même s'ils sont gênants pour la direction.
Présentation équitable	Rendre compte avec exactitude et vérité.	Le rapport reflète fidèlement les preuves. On ne grossit pas les risques mineurs.
Devoir de vigilance	Faire preuve de jugement professionnel.	L'auditeur évite de perturber la production (ex: tests de charge sur le serveur de boutique en heure de pointe).
Confidentialité	Protéger l'information sensible.	L'auditeur ne divulgue pas les failles de sécurité de Lizbiz's à l'extérieur ou aux concurrents.
Indépendance	Être impartial et sans conflit d'intérêt.	L'auditeur ne réalise pas l'audit de l'application qu'il a lui-même développée l'an passé.
Approche fondée sur la preuve	Baser les conclusions sur des faits vérifiables.	"Le serveur n'est pas à jour" est constaté par capture d'écran (preuve), pas par ouï-dire.

Table 3.1: Les 6 principes de l'audit selon ISO 19011

- Organigramme du service informatique.
- Cartographie des applications (Patrimoine applicatif).
- Politique de sécurité (PSSI).
- Procédures d'exploitation (sauvegardes, incidents).
- Rapports d'audit précédents (pour le suivi).

3.2.2 Analyse Préalable des Risques

Avant d'aller sur le terrain, l'auditeur identifie les zones sensibles.

Cas Pratique — Entreprise LiZbiZ

Analyse Lizbiz's : L'auditeur identifie que l'application "APPLICATION" gère la trésorerie. C'est une zone à risque élevé (fraude). La planification accordera donc plus de temps à l'audit du module "Paiement" qu'au module "Messagerie Interne".

3.2.3 Identification des Ressources

- **Humaines :** Combien d'auditeurs ? Quelles compétences (SQL, Réseau, Comptabilité) ?

- **Matérielles :** Besoin d'accès aux locaux ? Besoin d'un compte de test sur l'application ?

3.2.4 Le Rapport d'Orientation (ou Plan de Mission)

C'est le contrat. Il est validé par le commanditaire (PDG / COMEX). Il contient :

- **Contexte et Objectifs :** Pourquoi auditons-nous ?
- **Périmètre :** Ce qui est IN (ex: Module Vente) et ce qui est OUT (ex: Service Après-Vente).
- **Référentiels :** Normes utilisées (ISO 27001, COBIT, Règles internes).
- **Planning :** Dates clés (Réunion ouverture, Clôture, Remise rapport).
- **Équipe :** Noms et rôles.

3.3 Phase 2 : Exécution de la Mission (Le Terrain)

C'est la phase active de collecte et d'analyse.

3.3.1 Réunion d'Ouverture (Kick-off Meeting)

Elle marque le début officiel. **Objectifs :**

- Présenter l'équipe d'audit.
- Rappeler les objectifs et le périmètre.
- Confirmer le planning et les interlocuteurs (RACI).
- Rappeler les règles de confidentialité.

3.3.2 Techniques de Collecte d'Information

L'auditeur utilise trois techniques principales :

3.3.2.1 Les Entretiens

- Questions ouvertes : "Comment procédez-vous pour... ?"
- Questions fermées (validation) : "Est-ce que le mot de passe expire tous les 90 jours ?"
- **Astuce :** Toujours demander à voir la preuve de ce qui est dit ("Montrez-moi la procédure écrite").

3.3.2.2 L'Observation

Vérifier la réalité du terrain par rapport aux dires.

Cas Pratique — Entreprise LiZbiZ

Observation Lizbiz's : Le responsable dit "Les serveurs sont sous clé". L'auditeur observe que la porte de la salle serveur est ouverte car la climatisation est en panne.
Constat : Contrôle physique inefficace.

3.3.2.3 Les Tests Techniques et Analyse de Données

- **Tests de conformité :** Vérifier que les contrôles internes fonctionnent (ex: tenter de créer un compte sans autorisation).
- **Tests substantifs :** Vérifier l'exactitude des données (ex: extraction SQL pour vérifier les doublons de factures).

3.3.3 Consignation des Faits (Les Papiers de Travail)

L'auditeur note tout dans ses **Papiers de Travail (PT)**.

- Ils contiennent les preuves (captures d'écran, listings).
- Ils justifient les conclusions du rapport.
- Ils sont archivés (Classeur papier ou électronique GED).

3.4 Phase 3 : Communication des Résultats

L'audit ne vaut que par la communication de ses résultats.

3.4.1 Le Projet d'Observation

Pour chaque anomalie trouvée, l'auditeur rédige un projet d'observation structuré :

1. **Le Constat (What) :** Description factuelle de l'anomalie.
2. **La Cause (Why) :** Origine du problème (oubli, manque de formation, outil inadapté).
3. **Le Risque (So What) :** Conséquence potentielle pour l'entreprise.
4. **La Recommandation :** Action proposée pour corriger.

3.4.2 Le Contradictoire (Validation)

C'est une étape juridique et humaine critique. L'auditeur présente ses projets d'observation à l'audité.

- L'audité peut expliquer, apporter des preuves contraires, ou contester.
- L'auditeur garde la maîtrise de ses conclusions mais peut modifier le rapport si l'audité apporte des éléments nouveaux.

3.4.3 Le Rapport Final

Le rapport doit être :

- **Synthétique :** Une page de résumé pour la Direction.
- **Argumenté :** Les détails des constats et preuves.
- **Opérationnel :** Plan d'action clair avec responsables et échéances.

3.4.4 Réunion de Clôture

Présentation officielle des conclusions au commanditaire.

3.5 Phase 4 : Suivi de la Mission

L'audit ne s'arrête pas au rapport.

3.5.1 Le Plan d'Action

L'audité doit mettre en place les actions correctives.

3.5.2 Le Suivi (Follow-up)

Généralement 6 mois après, l'auditeur vérifie la mise en œuvre effective des recommandations.

- Recommandation appliquée ? (Clôturée).
- Recommandation non appliquée ? (Risque maintenu, à inscrire au rapport suivant).

3.6 Le Dossier d'Audit : Structure et Traçabilité

Le dossier d'audit est le garant de la qualité de la mission. Il doit répondre au principe de **reproductibilité** : tout auditeur tiers doit pouvoir aboutir aux mêmes conclusions en consultant les pièces.

Section Permanente (P) : Documents à validité pluriannuelle (Organigrammes, cartographie SI, contrats de maintenance, rapports d'audits passés).

Section Courante (C) : Documents spécifiques à la mission en cours :

- *Sous-dossier Planning :* Lettre de mission, budget temps, plan d'audit.
- *Sous-dossier Travaux :* Questionnaires, extractions de données (fichiers CSV/SQL de LiZbiZ), feuilles de tests.
- *Sous-dossier Preuves :* Captures d'écran, logs, copies de factures, enregistrements d'entretiens.

Section Conclusion (R) : Projets de rapports, réponses de l'audité (le contradictoire) et rapport final signé.

3.7 La Matrice des Risques : Priorisation des Travaux

L'auditeur utilise la matrice pour décider où porter ses efforts (Testing).

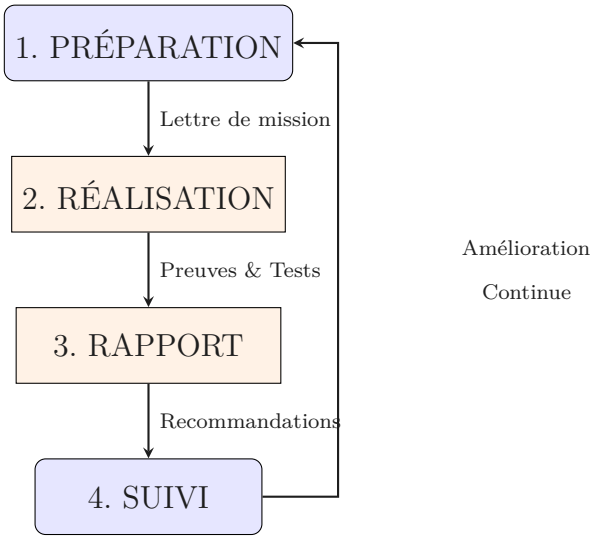
Probabilité ↓ / Impact →	Mineur	Modéré	Majeur	Critique
Quasi-certain	Moyen	Élevé	Extrême	Extrême
Probable	Faible	Moyen	Élevé	Extrême
Rare	Faible	Faible	Moyen	Élevé

Table 3.2: Matrice de criticité (Heatmap) pour le plan de test

Définition

Formule du Risque : $Risque = Impact \times Probabilit.$
En audit SI, l'impact est souvent évalué sur les critères DIC (Disponibilité, Intégrité, Confidentialité).

3.8 Workflow Séquentiel de la Mission



partie II

Référentiels et Typologies d'Audit

4

NORMES ET RÉFÉRENTIELS USUELS EN AUDIT DES SYSTÈMES D'INFORMATION

L'auditeur a besoin de "briques" techniques et organisationnelles pour évaluer la maturité d'un SI. Les référentiels fournissent les bonnes pratiques reconnues internationalement. Ce chapitre présente les trois piliers : COSO, COBIT et la série ISO 27000.

4.1 COSO : Le Modèle de Contrôle Interne

4.1.1 Présentation

Définition

COSO (Committee of Sponsoring Organizations) : Cadre de référence conceptuel du contrôle interne, publié en 1992 (révisé en 2013). C'est le modèle standard pour la gouvernance d'entreprise, souvent exigé par les lois sur la gouvernance (ex: Sarbanes-Oxley aux USA).

Bien que généraliste, COSO est le socle sur lequel s'appuient les autres référentiels informatiques.

4.1.2 Les Trois Objectifs

Le contrôle interne selon COSO vise à donner une assurance raisonnable sur la réalisation de trois objectifs :

1. **Réalisation et Optimisation des opérations** (Performance).
2. **Fiabilité des informations financières** (Comptabilité).
3. **Conformité aux lois et règlements** (Juridique).

4.1.3 Les Cinq Composantes (Le Cube COSO)

Pour atteindre ces objectifs, l'organisation doit mettre en place 5 composantes liées :

Cas Pratique — Entreprise LiZbiZ

Application Lizbiz's : L'audit du système de gestion des commandes chez Lizbiz's vérifiera si les 5 composantes COSO sont présentes : existe-t-il une procédure (Activité de contrôle) ? Les risques de fraude sont-ils évalués (Évaluation des risques) ? Les managers supervisent-ils les anomalies (Pilotage) ?

Composante	Description
Environnement de Contrôle	La culture, l'éthique, la compétence du personnel. (Le "ton donné par le sommet").
Évaluation des Risques	Identification et analyse des risques qui pourraient empêcher d'atteindre les objectifs.
Activités de Contrôle	Les politiques et procédures concrètes (Séparation des tâches, autorisations).
Information et Communication	La circulation de l'information nécessaire au pilotage (Qualité des données).
Pilotage (Monitoring)	Surveillance continue du système de contrôle interne (Audits, Supervision).

Table 4.1: Les 5 composantes du référentiel COSO

4.2 COBIT : La Gouvernance des SI

4.2.1 Présentation

Définition

COBIT (Control Objectives for Information and Related Technologies) : Référentiel de gouvernance et de management des SI développé par l'ISACA. Il fait le pont entre les métiers et l'IT.

C'est le référentiel de choix pour l'auditeur SI car il propose une liste d'objectifs de contrôle précis pour chaque processus informatique.

4.2.2 Objectifs et Apports

COBIT répond à la question : "Comment aligner l'IT sur la stratégie de l'entreprise ?". Il structure le SI en domaines et processus, offrant à l'auditeur une grille de lecture universelle.

4.2.3 Structure de COBIT (Version 5 / 2019)

COBIT divise la gouvernance et le management en 5 domaines principaux :

4.2.4 Utilisation par l'Auditeur

Pour chaque processus (ex: DS5 "Gérer la sécurité"), COBIT fournit :

- Un objectif de contrôle détaillé.
- Des indicateurs de performance (KPI).
- Un modèle de maturité (de 0 : Inexistant à 5 : Optimisé).

4.2.5 La Cascade d'Objectifs COBIT

L'un des points forts de COBIT est sa capacité à lier la stratégie métier aux objectifs techniques.

1. **Besoins des parties prenantes** (Bénéfices, Risques, Ressources).

Domaine	Contenu (Exemples de processus)
Evaluer, Diriger et Surveiller (EDM)	Gouvernance stratégique (EDM01 : Gouvernance cadre I&T).
Planifier et Organiser (PO)	Stratégie, Architecture, Budget (PO01 : Gérer le cad de management IT).
Acquérir et Implémenter (AI)	Projets, Développement, Intégration (AI06 : Gérer changements).
Délivrer et Servir (DS)	Exploitation, Support, Sécurité (DS01 : Gérer les opé tions).
Surveiller, Évaluer et Analyser (MEA)	Performance, Conformité (MEA02 : Surveiller et évalu le contrôle interne).

Table 4.2: Les domaines de COBIT

2. **Objectifs d'entreprise** (ex: Portefeuille de produits et services structurés).
3. **Objectifs d'alignement** (ex: Qualité des informations financières liées à l'IT).

4.3 La Série ISO 27000 : La Sécurité Normative

Alors que COBIT gère l'IT, la série ISO 27000 se concentre spécifiquement sur la **Sécurité de l'Information**.

4.3.1 Vue d'Ensemble

C'est une famille de normes internationales. Les plus critiques pour l'auditeur sont :

- **ISO 27001 :** Exigences pour un Système de Management de la Sécurité de l'Information (SMSI). C'est la norme *certifiable*.
- **ISO 27002 :** Code de bonne pratique. Liste détaillée des mesures de sécurité (contrôles) à implémenter.
- **ISO 27005 :** Gestion des risques en sécurité de l'information.
- **ISO 27006 :** Exigences pour les organismes de certification.

4.3.2 Importance pour l'Audit

1. **Critères d'audit :** ISO 27001 fournit les exigences ("Il faut une politique de sécurité"). L'auditeur vérifie si c'est fait.
2. **Mesures techniques :** ISO 27002 aide l'auditeur à proposer des recommandations techniques précises (ex: "Comment configurer l'authentification ?").

Cas Pratique — Entreprise LiZbiZ

Projet Lizbiz's : Suite à l'audit, la direction de Lizbiz's souhaite rassurer ses clients. Elle décide de se faire certifier **ISO 27001**. L'auditeur utilisera l'Annexe A de cette

norme (qui liste les contrôles obligatoires) comme grille d'évaluation pour le futur audit de certification.

4.4 Synthèse : Comment Choisir ?

L'auditeur combine souvent ces référentiels :

Référentiel	Angle d'attaque	Question clé pour l'auditeur
COSO	Gouvernance Globale	Les contrôles internes sont-ils bien conçus ?
COBIT	Processus IT	L'informatique est-elle bien gérée ?
ISO 27001	Sécurité Info	Le système est-il sécurisé et certifiable ?

Table 4.3: Comparatif des référentiels

Référentiel	Cible	Focus Auditeur	Livrable type
COSO	DG / Audit Interne	Contrôle Interne Global	Rapport de conformité Loi Sarbanes-Oxley
COBIT	DSI / Métiers	Gouvernance et Alignement	Matrice de maturité des processus SI
ISO 27001	RSSI / Sécurité	Management de la Sécurité	Certification SMSI (Audit de conformité)

Table 4.4: Tableau comparatif des référentiels d'audit

5

PRINCIPAUX TYPES D'AUDIT DANS LES SYSTÈMES D'INFORMATION

L'audit des SI ne se limite pas à la vérification des ordinateurs. Il couvre plusieurs domaines selon les enjeux de l'entreprise. Ce chapitre détaille les principaux types d'audits rencontrés en milieu professionnel.

5.1 Audit des Applications en Service

C'est l'audit le plus courant. Il porte sur un logiciel utilisé quotidiennement par l'entreprise (ERP, CRM, Comptabilité).

5.1.1 Objectifs

L'auditeur vérifie que l'application assure :

- **La Fiabilité :** Les données sont exactes (Intégrité).
- **La Sécurité :** Les accès sont restreints et contrôlés.
- **La Disponibilité :** L'application est accessible quand nécessaire.

5.1.2 Les Deux Dimensions de l'Audit

1. **Contrôles Généraux (General Controls) :** L'environnement global.
   - Le système d'exploitation est-il sécurisé ?
   - La salle serveur est-elle verrouillée ?
   - Les sauvegardes fonctionnent-elles ?
2. **Contrôles d'Application (Application Controls) :** Le logiciel métier.
   - L'application gère-t-elle les droits d'accès fines ?
   - Les données de sortie sont-elles cohérentes avec les entrées ?
   - Y a-t-il une piste d'audit (logs) des actions utilisateurs ?

Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : Audit de l'APPLICATION L'auditeur vérifie le module comptable.

- *Test Général :* Le serveur Linux hébergeant la base de données est-il à jour (Patch) ?

➢ *Test d'Application :* Un utilisateur peut-il modifier une facture déjà validée sans laisser de trace ? (Test de piste d'audit).

5.2 Audit de la Fonction Informatique (DSI)

Ici, on n'audite pas une machine, mais un service : la Direction des Systèmes d'Information.

5.2.1 Objectifs

Évaluer l'organisation, la gestion des ressources et l'efficacité de la DSI.

5.2.2 Points de Contrôle Typiques

Domaine	Exemples de points de contrôle
Organisation	Clarté de l'organigramme, séparation des tâches (Développeur vs Administrateur).
Gestion du Personnel	Procédures d'embauche/départ (retrait des accès), formation continue.
Gestion des Actifs	Inventaire du matériel, gestion des licences logicielles.
Contrôle de Gestion	Suivi des budgets informatiques, coûts des projets.

5.3 Audit des Projets Informatiques

L'audit intervient souvent **pendant** le projet (Audit de jalons) ou à la fin (Réception).

5.3.1 Objectifs

S'assurer que le projet sera livré conformément aux attentes (Qualité, Délai, Coût).

5.3.2 Phases Clés à Auditer

1. **Phase d'Étude (Cahier des charges) :** Les besoins utilisateurs sont-ils bien traduits ? Le budget est-il réaliste ?
2. **Phase de Développement :** Les développeurs suivent-ils les normes de codage sécurisé ? Les tests unitaires sont-ils passés ?
3. **Phase de Recette (Tests) :** Les tests couvrent-ils tous les scénarios métier ?
4. **Phase de Mise en Production :** Les procédures de migration des données sont-elles sécurisées ?

■ Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : Projet IA L'audit du projet d'intégration de l'IA dans la logistique doit vérifier que les données personnelles des clients ne sont pas utilisées illégalement par l'algorithme d'apprentissage (Conformité RGPD).

5.4 Audit de Sécurité Informatique

C'est un audit spécialisé, souvent technique (Pentest, Audit configuration).

5.4.1 Objectifs

Mesurer la résistance du SI aux menaces (Hacking, Malveillance interne, Sinistres).

5.4.2 Les Piliers de la Sécurité (D.I.C.T.)

L'audit de sécurité vérifie :

- **Disponibilité :** Le système est-il robuste face aux pannes ou DDoS ?
- **Intégrité :** Les données peuvent-elles être modifiées sans autorisation ?
- **Confidentialité :** L'information n'est-elle accessible qu'aux personnes habilitées ?
- **Traçabilité :** Peut-on identifier qui a fait quoi et quand (Logs) ?

5.4.3 Méthodologie Technique

- **Audit de configuration :** Vérification des paramètres (ex: mots de passe forts activés).
- **Tests d'intrusion (Pentest) :** Simulation d'une attaque réelle pour trouver les failles.
- **Audit physique :** Contrôle des accès aux locaux, destruction des documents confidentiels.

5.5 Autres Types d'Audits

5.5.1 Audit du Support Utilisateur et Gestion du Parc

Vérification de la gestion du Helpdesk (tickets, SLA) et de l'inventaire matériel (disparition de PC, gestion des cycles de vie).

5.5.2 Audit de la Fonction Étude (Développement)

Focus sur la qualité du code, la documentation technique et la gestion des versions (Versionning).

5.6 Audit de la Continuité d'Activité et de la Résilience

L'auditeur doit s'assurer que l'organisation est capable de maintenir ou de reprendre ses activités critiques après un sinistre majeur (incendie, cyberattaque massive, panne électrique). Ce volet s'appuie sur le référentiel **ISO 22301**.

5.6.1 Concepts Clés de Résilience

- **BIA (Business Impact Analysis) :** L'audit vérifie si une analyse d'impact a été réalisée pour identifier les processus vitaux.
- **MTPD (Maximum Tolerable Period of Disruption) :** La durée maximale d'interruption supportable par l'entreprise avant que sa survie ne soit menacée.

- **RTO (Recovery Time Objective) :** L'objectif de temps pour la remise en service des systèmes.
- **RPO (Recovery Point Objective) :** La perte de données maximale admissible (déterminée par la fréquence des sauvegardes).

★ Attention

Point de contrôle : Un RTO de 4h avec des sauvegardes (RPO) de 24h est-il cohérent avec les besoins métiers de **LiZbiZ** ? L'auditeur doit relever toute inadéquation entre les capacités techniques et les exigences de la Direction.

5.7 Audit des Tiers, du Cloud et de l'Outsourcing

À l'heure du "Tout Cloud", l'auditeur ne peut s'arrêter aux murs de l'entreprise. Si **LiZbiZ** héberge ses données clients sur AWS ou Azure, le périmètre d'audit doit s'adapter.

5.7.1 Le "Droit d'Audit" et les Rapports SOC

- **Clause d'Audit :** Vérifier la présence d'une clause contractuelle permettant à l'entreprise (ou ses mandataires) d'auditer le prestataire.
- **Rapports SOC (Service Organization Controls) :** En l'absence d'audit direct, l'auditeur doit analyser les rapports de certification du prestataire :
  - **SOC 1 (Type II) :** Focus sur les contrôles financiers.
  - **SOC 2 (Type II) :** Focus sur la sécurité, disponibilité et confidentialité.

5.8 Focus technique : Les Contrôles Applicatifs (IPO)

Pour l'audit de l'APPLICATION de **LiZbiZ**, l'auditeur utilise le modèle **Input-Process-Output** pour s'assurer de l'intégrité des données.

Étape	Objectif de Contrôle	Exemple de Test d'Audit
Entrée (Input)	Données complètes, exactes et autorisées.	Tester si le système rejette une commande avec un prix négatif.
Traitement (Process)	Calculs conformes aux règles métiers.	Vérifier que le calcul de la TVA sur les articles high-tech est exact.
Sortie (Output)	Résultats distribués aux bonnes personnes.	S'assurer que les factures générées ne sont accessibles qu'au client concerné.

Table 5.1: Matrice de contrôle applicatif IPO

6

CONCEPTION D'UN OUTIL D'AIDE À L'AUDIT DES SYSTÈMES D'INFORMATION

6.1 Pourquoi un outil structuré d'aide à l'audit ?

L'audit des systèmes d'information est une démarche intellectuelle exigeante : l'auditeur doit simultanément maintenir une vue d'ensemble du périmètre audité, descendre au niveau du détail opérationnel le plus fin, collecter des preuves, formuler des risques et en anticiper les conséquences pour l'organisation. Conduite sans support méthodique, cette démarche expose à deux écueils symétriques et également coûteux : l'omission de zones à risque et la redondance d'investigations sans valeur ajoutée.

Un *outil d'aide à l'audit* est un dispositif documentaire et computationnel qui matérialise la logique de la mission d'audit sous une forme directement opérationnelle. Il ne remplace pas le jugement professionnel de l'auditeur ; il le libère des tâches mécaniques de mémorisation et de structuration, pour qu'il puisse concentrer son attention sur ce qui requiert réellement une expertise : l'interprétation des faits et la formulation des recommandations.

■ Définition

Outil d'aide à l'audit Un outil d'aide à l'audit est un référentiel structuré qui, pour un domaine d'audit donné, décompose de manière exhaustive et ordonnée l'ensemble des vérifications à conduire, depuis les grands axes de contrôle jusqu'aux questions élémentaires à poser sur le terrain, en associant à chaque question le risque qu'elle vise à détecter et la conséquence organisationnelle que l'absence de contrôle ferait peser sur l'entité auditée.

6.1.1 Fonctions de l'outil

Un outil d'aide à l'audit remplit quatre fonctions complémentaires.

Fonction de complétude. En déployant systématiquement la totalité des niveaux de décomposition, l'outil garantit qu'aucun point de contrôle pertinent n'est oublié, quelle que soit l'expérience de l'auditeur qui le met en œuvre.

Fonction de traçabilité. Chaque observation de terrain est rattachée, via la structure de l'outil, à un point de contrôle, un objectif et un critère précis. Cette chaîne de traçabilité est indispensable pour que le rapport d'audit soit opposable : chaque constat

doit pouvoir être remonté jusqu'au référentiel qui le fonde.

Fonction de standardisation. Dès lors que l'outil est partagé au sein d'une équipe ou d'une institution, il assure la comparabilité des missions d'audit conduites à des moments différents ou par des auditeurs différents sur un même périmètre. Cette standardisation est la condition sine qua non d'un suivi pluriannuel de la maturité organisationnelle.

Fonction d'automatisation. Implémenté dans un tableur, l'outil peut intégrer des formules de scoring, des indicateurs de couverture, des alertes de non-conformité et des tableaux de bord synthétiques, transformant ainsi un simple guide de questions en un véritable instrument de pilotage de la mission.

6.1.2 Ancrage normatif

La nécessité d'un tel outil n'est pas une construction ex nihilo : elle est explicitement posée par les principaux référentiels internationaux de l'audit des SI.

COBIT 2019 structure l'évaluation des processus IT en objectifs de gouvernance et de gestion, eux-mêmes décomposés en pratiques, activités et indicateurs ; cette arborescence est le prototype même de la décomposition hiérarchique décrite dans ce chapitre. Les normes ISACA (CISA Review Manual) prescrivent une approche par domaines et sous-domaines, avec des objectifs de contrôle définis pour chacun. La norme ISO/IEC 27001 organise la sécurité de l'information en 114 mesures de contrôle regroupées en 14 domaines, dont la vérification lors d'un audit suit précisément la logique du critère, de l'élément probant et de la question d'évaluation. Le COSO, enfin, articule le contrôle interne en cinq composantes dont la vérification lors d'un audit suit la même progression : assertion (objectif de contrôle), test (critère et question), preuve (élément requis), constat (risque), et impact (conséquence).

■ Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : la nécessité vécue de l'outil

Lors d'une mission d'audit de l'application de gestion des stocks de Lizbiz's, l'équipe d'audit arrive sur site sans grille structurée. Elle identifie un problème d'accès non autorisé aux données de production, mais ne documente pas systématiquement les questions connexes : la gestion des profils, la piste d'audit, la journalisation des modifications. Le rapport conclut à une faille de contrôle d'accès. Six mois plus tard, un audit externe révèle que les données sensibles étaient également accessibles via un module non inventorié. La faille était pourtant couverte par la grille de contrôle standard, elle avait été omise faute d'un outil de décomposition systématique. L'outil d'aide à l'audit aurait rendu cette omission impossible.

6.2 La méthode de décomposition hiérarchique

La méthode de décomposition hiérarchique est le cœur intellectuel de l'outil d'aide à l'audit. Elle repose sur un principe simple : tout audit, quel que soit son type ou

son périmètre, peut être entièrement représenté par une arborescence à huit niveaux, depuis le domaine le plus général jusqu'aux conséquences les plus concrètes de chaque défaillance de contrôle.

Définition

Méthode de décomposition hiérarchique La méthode de décomposition hiérarchique est un cadre d'analyse qui structure tout périmètre d'audit en une succession ordonnée de niveaux d'abstraction décroissante, chaque niveau étant entièrement dérivé du précédent selon une relation logique de type *général* → *particulier*. Elle produit, pour chaque domaine audité, une arborescence exhaustive reliant le champ d'audit (niveau 1) aux conséquences organisationnelles des risques détectés (niveau 8).

6.2.1 Vue d'ensemble de l'arborescence

Les huit niveaux de la décomposition sont les suivants :

1. **Domaine** : le champ d'audit considéré ;
2. **Point de contrôle** : les grandes thématiques à examiner dans ce domaine ;
3. **Objectif de contrôle** : ce que l'auditeur cherche à vérifier pour chaque point ;
4. **Critère** : les conditions précises dont la réunion établit que l'objectif est atteint ;
5. **Élément requis** : les documents ou preuves tangibles à collecter pour renseigner chaque critère ;
6. **Question d'évaluation** : la formulation interrogative opérationnelle dérivée du critère ;
7. **Risque** : ce que l'absence ou la défaillance du contrôle associé à la question fait peser sur l'entité ;
8. **Conséquence** : l'impact organisationnel, opérationnel ou réglementaire de la réalisation du risque.

La figure suivante représente cette arborescence :

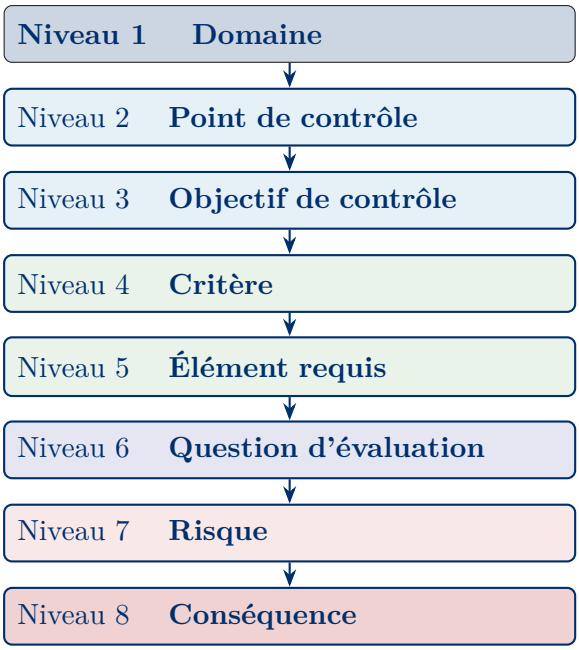


Figure 6.1: Arborescence de la méthode de décomposition hiérarchique

6.3 Rôle et logique de chaque palier

6.3.1 Niveau 1. Le Domaine

Définition

Domaine Le domaine désigne le champ d'audit considéré dans son ensemble, c'est-à-dire l'entité, la fonction, le processus ou le système sur lequel porte la mission.

Le domaine est le point d'entrée de toute décomposition ; il répond à la question : *qu'est-ce qu'on audite ?* Il peut s'agir d'une application informatique en service, de la fonction informatique (DSI), d'un projet informatique, du support utilisateur, de la sécurité informatique, de la fonction étude, ou de tout autre périmètre défini dans le mandat d'audit.

Le domaine ne contient en lui-même aucun contenu évaluable ; il sert exclusivement de label d'en-tête pour la feuille de calcul correspondante dans l'outil. Chaque domaine donne lieu à une feuille distincte.

Clé de conception. Un domaine bien délimité est un domaine dont les frontières sont acceptées par l'audité. La lettre de mission doit formaliser cette délimitation avant le début des travaux de terrain.

6.3.2 Niveau 2. Le Point de contrôle

Définition

Point de contrôle Un point de contrôle est une thématique majeure du domaine audité, identifiée comme un axe de vérification cohérent et autonome. Il regroupe l'ensemble des vérifications portant sur une même composante fonctionnelle, organisationnelle ou technique du domaine.

Les points de contrôle constituent le plan de l'audit ; ils répondent à la question : *sur quels axes doit-on se prononcer ?* Ils sont définis par référence à un référentiel reconnu : guide d'audit des SI (IFACI/CIGREF), COBIT, ISO 27001, guide ISACA, ou document normatif sectoriel. Leur nombre varie selon le type d'audit : six pour l'audit des applications en service, dix pour l'audit de sécurité, quinze pour l'audit des projets informatiques.

Clé de conception. Un bon point de contrôle est *homogène* (toutes les vérifications qu'il recouvre concernent bien la même composante), *exhaustif* (il ne laisse pas de zone d'ombre dans sa thématique) et *indépendant* des autres points de contrôle du même domaine (pas de recouvrement).

6.3.3 Niveau 3. L'Objectif de contrôle

Définition

Objectif de contrôle Un objectif de contrôle est une assertion précise sur ce qui doit être vérifié au sein d'un point de contrôle. Il formule, de manière affirmative et vérifiable, l'état attendu d'une composante du système audité.

Les objectifs de contrôle répondent à la question : *que doit-on s'assurer ?* Ils sont formulés à l'infinitif : *S'assurer que...* ou *Vérifier que....* Cette formulation n'est pas stylistique : elle rappelle que l'objectif engage la responsabilité de l'auditeur, il doit apporter la preuve que la vérification a bien été conduite.

Un point de contrôle peut comporter plusieurs objectifs de contrôle. Par exemple, le point de contrôle *Organisation* dans l'audit des applications en service comporte dix objectifs, allant de l'existence d'un comité informatique jusqu'à la disponibilité d'un guide utilisateur.

Clé de conception. Chaque objectif doit être *formulé en termes d'état* (ce qui doit exister ou être effectif), et non en termes d'action (ce que l'auditeur va faire) ; la formulation de l'action relève du niveau 6 (question d'évaluation).

6.3.4 Niveau 4. Le Critère

Définition

Critère Un critère est une condition élémentaire et vérifiable dont la satisfaction contribue à établir qu'un objectif de contrôle est atteint. Il décompose l'objectif en assertions unitaires, chacune susceptible d'être évaluée indépendamment.

Les critères répondent à la question : *à quelles conditions peut-on considérer que l'objectif est rempli ?* Ils sont formulés sous la forme de propositions assertives au présent de l'indicatif : *Le comité est présidé par le Directeur Général ; les directions utilisatrices sont représentées ; etc.*

La granularité du critère doit être telle qu'il ne soit ni trop large (auquel cas il se confondrait avec l'objectif) ni trop étroit (auquel cas il deviendrait une simple modalité). Un critère bien formulé peut être binaire : soit il est vérifié, soit il ne l'est pas.

Clé de conception. La somme des critères associés à un objectif doit être à la fois nécessaire et suffisante : si tous les critères sont satisfaits, l'objectif est atteint ; si l'un d'eux ne l'est pas, l'objectif est partiellement ou totalement défaillant.

6.3.5 Niveau 5. L'Élément requis

Définition

Élément requis Un élément requis est un document, un enregistrement, un artefact ou une preuve tangible dont la production ou la présentation par l'audité est nécessaire pour que l'auditeur puisse se prononcer sur la satisfaction d'un critère.

Les éléments requis répondent à la question : *quelles preuves faut-il collecter ?* Ce sont les pièces du dossier d'audit : procès-verbaux de réunion, décisions de nomination, politiques formalisées, contrats, journaux système, rapports d'activité, etc.

Ce niveau est le lien entre la démarche analytique de l'auditeur (les niveaux 1 à 4) et le terrain de la mission (la collecte documentaire). La liste des éléments requis constitue, une fois compilée sur l'ensemble des critères, le *tableau de demandes de documents* à remettre à l'audité en début de mission.

Clé de conception. Un élément requis doit être *nominatif* (document spécifique, pas une catégorie) et *daté* si possible (version en vigueur, exercice concerné), de manière à ce que l'audité sache précisément ce qui est attendu de lui.

6.3.6 Niveau 6. La Question d'évaluation

Définition

Question d'évaluation Une question d'évaluation est la formulation interrogative opérationnelle d'un critère ; c'est la question que l'auditeur pose à l'audité, ou qu'il se pose lui-même lors de l'examen d'un document, pour vérifier la satisfaction du critère correspondant.

Les questions d'évaluation répondent à la question : *comment vérifier concrètement le critère sur le terrain ?* Elles sont formulées en propositions interrogatives directes : *Existe-t-il un comité informatique ? Le comité est-il présidé par le Directeur Général ?*

Ce niveau est le *questionnaire d'audit* : l'ensemble des questions d'évaluation d'un domaine, une fois extrait de l'outil, constitue le guide d'entretien utilisable lors des réunions avec l'audité ou lors de l'examen documentaire.

Clé de conception : la réponse trichotomique. Contrairement à une idée reçue, la question d'évaluation ne doit pas être strictement binaire. L'expérience du terrain révèle qu'une troisième situation échappe systématiquement à la dichotomie Oui/Non : celle où l'auditeur ne dispose pas d'une information suffisante pour se prononcer, non par manque de diligence, mais parce que l'information elle-même n'existe pas, ne circule pas ou n'est pas accessible au sein de l'entité auditée.

L'outil retient donc un *système de réponse trichotomique* :

- **O** (*Oui*), le critère est satisfait ; la preuve a été collectée et est probante ;
- **N** (*Non*), le critère n'est pas satisfait ; la défaillance est avérée ;
- **PAS** (*Pas Assez de Savoir*), également noté **NEK** (*Not Enough Knowledge*), l'auditeur ne dispose pas d'une information suffisante pour conclure : le document requis n'a pas été produit, les interlocuteurs ne peuvent pas répondre, ou les réponses obtenues sont contradictoires.

La modalité PAS/NEK n'est pas un aveu d'échec méthodologique ; elle est au contraire un *signal diagnostique de première importance*. Deux interprétations organisationnelles lui sont associées :

1. **Défaillance du contrôle interne** : si une proportion élevée de réponses PAS/NEK se concentre sur un point de contrôle donné, cela indique que les mécanismes de contrôle de ce point sont soit inexistants, soit non documentés, soit non appliqués, ce qui constitue en soi un risque, indépendamment du fait que le contrôle soit ou non en place.
2. **Défaut de circulation de l'information** : si les réponses PAS/NEK sont dispersées sur l'ensemble des points de contrôle et des interlocuteurs rencontrés, cela révèle que l'information pertinente pour le fonctionnement de l'organisation ne circule pas

correctement : les acteurs ne savent pas ce qui se fait, ce qui existe ou ce qui est décidé ailleurs dans leur propre organisation.

Mesure de l'incertitude par l'entropie de Shannon. La proportion de réponses PAS/NEK dans un domaine ou sur l'ensemble d'un audit peut être quantifiée par l'*entropie informationnelle de Shannon*, appliquée à la distribution des trois modalités de réponse. Pour un domaine comportant n questions, en notant p_O, p_N et p_P les proportions respectives de réponses O, N et PAS/NEK, l'entropie de Shannon s'écrit :

$$H = -\,p_O \log_2 p_O \;-\; p_N \log_2 p_N \;-\; p_P \log_2 p_P \quad \in [0,\ \log_2 3 \approx 1{,}585 \text{ bits}] \tag{6.1}$$

L'entropie H est nulle lorsque toutes les réponses sont identiques (certitude complète) et maximale ($\approx$ 1,585 bits) lorsque les trois modalités sont équiprobables (incertitude maximale). En pratique :

- une entropie élevée sur un domaine signale une *zone grise* : l'auditeur ne peut pas se prononcer de manière fiable, ce qui est en soi un constat d'audit ;
- la cartographie des entropies par domaine et par point de contrôle constitue un *indicateur de qualité de l'information* au sein de l'entité, complémentaire au taux de conformité.

Ce double signal, taux de conformité d'une part, entropie informationnelle d'autre part, fait de l'outil un instrument à deux dimensions : il mesure à la fois *ce qui ne va pas* (réponses N) et *ce qu'on ne sait pas* (réponses PAS/NEK), les deux dimensions pouvant pointer des pathologies organisationnelles distinctes.

6.3.7 Niveau 7. Le Risque

Définition

Risque Dans la grille de décomposition, le risque désigne la situation de défaillance ou d'absence de contrôle que l'auditeur identifie lorsque la réponse à une question d'évaluation est négative. Il est formulé comme l'antithèse du critère correspondant.

Les risques répondent à la question : *que se passe-t-il si la réponse à la question est négative ?* Ils sont formulés comme des assertions descriptives de l'état de non-conformité : *Inexistence d'un comité informatique ; Le comité n'est pas présidé par le Directeur Général ; Les directions utilisatrices ne sont pas représentées.*

Ce niveau est *mécaniquement dérivé* du niveau 6 : à chaque question dont la réponse est Non correspond un risque formalisé. L'outil peut donc générer automatiquement la liste des risques actifs à partir des réponses saisies par l'auditeur, et constituer ainsi la base de la cartographie des risques de la mission.

Clé de conception. Le risque doit être formulé au niveau de l'état de non-conformité constaté, pas au niveau de la cause (qui relève de l'analyse de l'auditeur) ni de l'impact (qui relève du niveau 8). La frontière avec les niveaux adjacents doit être tenue pour que le scoring soit cohérent.

6.3.8 Niveau 8. La Conséquence

Définition

Conséquence La conséquence est l'impact organisationnel, opérationnel, financier ou réglementaire que la réalisation du risque fait peser sur l'entité auditée. Elle représente le *préjudice potentiel* que l'absence du contrôle concerné rend possible.

Les conséquences répondent à la question : *pourquoi ce risque est-il grave ?* Elles sont formulées en termes d'impacts mesurables ou plausibles : *Incohérence des choix stratégiques ; Application non adaptée aux besoins du métier ; Perte de données sensibles ; Non-conformité réglementaire exposant l'entité à des sanctions.*

Ce niveau justifie, pour chaque risque identifié, la nécessité d'une recommandation dans le rapport d'audit. La conséquence est l'argument de fond qui permet à l'auditeur de convaincre la direction auditée de l'urgence d'une action corrective.

Clé de conception. La conséquence doit être *proportionnée* : une conséquence surévaluée crédite l'auditeur d'un alarmisme peu professionnel ; une conséquence sous-évaluée banalise un constat qui mérite attention. Elle doit également être *rattachée au contexte de l'entité* et non générique : l'absence d'un PCA n'a pas les mêmes conséquences pour un opérateur de services critiques que pour une PME commerciale.

6.4 Universalité et adaptabilité de la méthode

Un trait essentiel de la méthode de décomposition hiérarchique est son *invariance structurelle* : la succession des huit niveaux reste identique quel que soit le type d'audit considéré. Ce qui change d'un type à l'autre, c'est uniquement le contenu de chaque niveau, le nombre de points de contrôle, la formulation des objectifs, la nature des éléments requis, mais jamais la logique de décomposition elle-même.

Invariance structurelle de la décomposition

Pour tout domaine d'audit $\mathcal{D}$, il existe une décomposition hiérarchique $\mathcal{H}(\mathcal{D})$ en huit niveaux tels que :

1. Chaque élément de niveau k est intégralement dérivé d'un et d'un seul élément de niveau $k-1$;
2. La réunion de tous les éléments de niveau k associés à un élément de niveau $k-1$ couvre exhaustivement cet élément ;
3. Deux éléments de même niveau rattachés au même parent de niveau $k-1$ sont

disjoints.

Cette propriété garantit que l'outil d'audit construit à partir de $\mathcal{H}(\mathcal{D})$ est à la fois exhaustif, non redondant et entièrement traçable.

Cette invariance a une conséquence pratique immédiate : *apprendre la méthode une fois suffit pour l'appliquer à n'importe quel type d'audit.* Un auditeur qui maîtrise la décomposition sur l'audit des applications en service peut, en changeant le contenu des cellules sans changer la structure du tableur, construire une grille d'audit de la sécurité informatique, d'un projet ou de la fonction DSI.

Le tableau 6.1 illustre la variabilité du contenu avec l'invariance de la structure sur trois types d'audit.

Table 6.1: Invariance structurelle : le même niveau pour trois domaines différents

Niveau	**Audit Applications**	**Audit Sécurité**	**Audit Projets**
1. Domaine	Application en service	Sécurité informatique	Projet informatique
2. Point de contrôle	Organisation (6 pts)	Politique de sécurité (10 pts)	Planification (15 pts)
3. Objectif	S'assurer de l'existence d'un comité informatique	S'assurer qu'une politique formalisée existe	S'assurer de l'existence d'un planning directeur
4. Critère	Le comité est présidé par le DG	La politique couvre l'ensemble du SI	Le planning intègre une gestion optimale des ressources
5. Élément requis	PV de session du comité	Document de politique de sécurité en vigueur	Planning directeur signé et révisé
6. Question	Le comité est-il présidé par le DG ?	La politique couvre-t-elle l'ensemble du SI ?	Un planning directeur commun existe-t-il ?
7. Risque	Le comité n'est pas présidé par le DG	La politique ne couvre pas l'ensemble du SI	Absence de planning directeur commun
8. Conséquence	Décisions prises par des acteurs sans niveau décisionnel adéquat	Zones du SI non couvertes exposées sans protection	Incohérence dans la planification, dépassements de délais

6.5 Structuration du fichier Excel de l'outil d'aide à l'audit

L'implémentation naturelle de la méthode de décomposition hiérarchique est un classeur tableur (Microsoft Excel ou LibreOffice Calc). Sa structure reflète directement l'arbo-

rescence à huit niveaux : chaque feuille correspond à un domaine (niveau 1), et chaque ligne correspond à une feuille terminale de l'arborescence, c'est-à-dire à la combinaison complète des huit niveaux pour une unité élémentaire de vérification.

6.5.1 Architecture du classeur

Organisation en feuilles. Le classeur comporte autant de feuilles que de domaines d'audit : une feuille par type d'audit (application en service, fonction informatique, projets, support/parc, sécurité, fonction étude). Une feuille supplémentaire, nommée `SYNTHÈSE`, agrège les indicateurs de l'ensemble des domaines.

Nommage des feuilles. Chaque feuille est nommée de manière à identifier sans ambiguïté le domaine qu'elle couvre, selon la convention : `[Nř]_[SIGLE_DOMAINE]`, par exemple : `01_APPLI`, `02_DSI`, `03_PROJETS`, `04_SUPPORT`, `05_SECURITE`, `06_ETUDE`.

6.5.2 Structure de chaque feuille de domaine

Chaque feuille de domaine comporte les colonnes suivantes, dans l'ordre :

Table 6.2: Structure standard d'une feuille de domaine dans l'outil d'aide à l'audit

Col.	En-tête	Contenu et rôle
A	`DOMAINE`	Nom du domaine audité (identique sur toutes les lignes de la feuille ; sert à la consolidation dans la synthèse).
B	`POINT DE CONTRÔLE`	Libellé du point de contrôle (niveau 2). Plusieurs lignes successives partagent le même libellé, regroupées visuellement par un fond coloré alterné.
C	`OBJECTIF DE CONTRÔLE`	Libellé de l'objectif de contrôle (niveau 3), formulé à l'infinitif (*S'assurer que...*, *Vérifier que...*).
D	`CRITÈRE`	Assertion élémentaire à vérifier (niveau 4), formulée au présent de l'indicatif.
E	`ÉLÉMENT REQUIS`	Document ou preuve à collecter (niveau 5).
F	`QUESTION D'ÉVALUATION`	Question posée sur le terrain (niveau 6), appelant une réponse trichotomique : `O` / `N` / `PAS`.
G	`RÉPONSE`	Cellule de saisie auditeur : réponse *trichotomique* obligatoire. `O` (*Oui*) : critère satisfait, preuve collectée. `N` (*Non*) : critère non satisfait, défaillance avérée. `PAS` (*Pas Assez de Savoir*, aussi noté `NEK` : *Not Enough Knowledge*) : information insuffisante pour conclure, signalant soit une défaillance du contrôle interne, soit un défaut de circulation de l'information. C'est la *seule colonne remplie manuellement* lors de la mission ; toutes les autres colonnes calculées en dépendent.
H	`RISQUE`	Formulation du risque associé à une réponse négative (niveau 7). Affiché en rouge automatiquement si la réponse en col. G est N.
I	`CONSÉQUENCE`	Impact organisationnel de la réalisation du risque (niveau 8).
J	`CRITICITÉ`	Score calculé automatiquement (formule) : pondération de la probabilité d'occurrence du risque et de la gravité de la conséquence. Exprimé sur une échelle 1–4 ou 1–9 selon le référentiel retenu.
K	`STATUT`	Formule conditionnelle : `CONFORME` si `G` = `O` ; `NON CONFORME` si `G` = `N` ; `ZONE GRISE` si `G` = `PAS`. Mise en forme conditionnelle : vert / rouge / orange ambré respectivement.
L	`RECOMMANDATION`	Cellule de saisie auditeur : action corrective recommandée. Renseignée pour les statuts `NON CONFORME` et `ZONE GRISE`.
M	`PRIORITÉ`	Urgence de la recommandation : `IMMÉDIATE`, `COURT TERME` ou `MOYEN TERME`. Calculée à partir du score de criticité (col. J).
N	`COMMENTAIRE`	Champ libre de l'auditeur : nuance, contexte,

6.5.3 Fonctionnement des formules d'automatisation

Trois familles de formules font de la feuille de calcul un outil actif et non un simple formulaire statique.

Formule de statut (colonne K). Le statut de chaque ligne est calculé automatiquement à partir de la réponse trichotomique saisie en colonne G :

```
=SI(G2="O";"CONFORME";SI(G2="N";"NON CONFORME";"ZONE GRISE"))
```

La mise en forme conditionnelle applique un fond vert au statut `CONFORME`, rouge au statut `NON CONFORME`, et orange ambré au statut `ZONE GRISE`. Ce dernier appel visuel signale à l'auditeur que la ligne exige un approfondissement : investigation complémentaire, relance de l'audité ou recherche d'une source d'information alternative.

Formule de criticité (colonne J). La criticité est activée pour les réponses `N` et `PAS` : une réponse PAS/NEK porte un risque potentiel aussi réel qu'une réponse négative avérée, même si sa nature diffère (incertitude vs défaillance). La formule type est :

```
=SI(G2="O";"";SI(G2="N";PROBABILITE*GRAVITE;PROBABILITE*GRAVITE*0.7))
```

Le coefficient 0,7 appliqué au score PAS/NEK traduit l'incertitude inhérente : le risque est réel mais non entièrement établi. Ce coefficient est paramétrable selon la politique de risque de l'institution auditrice.

Formule d'entropie (colonne O, niveau point de contrôle). L'entropie de Shannon est calculée sur les lignes de sous-total agrégées par point de contrôle. En nommant `NbO`, `NbN`, `NbP` les compteurs de réponses O, N et PAS dans le groupe, et `NbTotal` leur somme :

```
=SI(NbTotal=0;"";
   -SI(NbO=0;0;(NbO/NbTotal)*LOG(NbO/NbTotal;2))
   -SI(NbN=0;0;(NbN/NbTotal)*LOG(NbN/NbTotal;2))
   -SI(NbP=0;0;(NbP/NbTotal)*LOG(NbP/NbTotal;2)))
```

La valeur résultante, comprise entre 0 et $\log_2 3 \approx 1{,}585$ bits, est affichée avec une mise en forme conditionnelle à gradient : blanc pour $H < 0{,}5$ (certitude), jaune pour $0{,}5 \leq H < 1{,}0$ (incertitude modérée), rouge pour $H \geq 1{,}0$ (zone grise critique).

Formule de priorité (colonne M). La priorité de la recommandation est dérivée du score de criticité :

```
=SI(J2>=7;"IMMÉDIATE";SI(J2>=4;"COURT TERME";"MOYEN TERME"))
```

6.5.4 La feuille de synthèse

La feuille `SYNTHÈSE` agrège automatiquement, pour l'ensemble des domaines, les indicateurs de couverture et de qualité de la mission. Elle comporte :

- le **taux de couverture** par domaine : proportion de questions auxquelles une réponse a été saisie (mesure de l'avancement de la mission) ;
- le **taux de conformité** par domaine : proportion de réponses O sur l'ensemble des questions évaluées ;
- le **taux d'incertitude** par domaine : proportion de réponses PAS/NEK, indicateur direct de la qualité de l'information disponible dans l'entité auditée ;
- la **cartographie entropique** : histogramme des entropies de Shannon par point de contrôle, permettant de visualiser d'un coup d'œil les zones grises les plus denses ;
- la **cartographie des risques** : tableau croisé des risques actifs (réponses N et PAS/NEK) par domaine et par niveau de criticité ;
- le **plan d'action synthétique** : liste consolidée des recommandations de priorité `IMMÉDIATE` et `COURT TERME`, extraites automatiquement des feuilles de domaine.

Ces indicateurs sont visualisés dans un tableau de bord graphique à deux dimensions : la dimension *conformité* (ce qui ne va pas, réponses N) et la dimension *incertitude* (ce qu'on ne sait pas, réponses PAS/NEK), représentées sur un radar chart à six axes (un par domaine), inséré dans la feuille `SYNTHÈSE`.

■ Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : trichotomie O / N / PAS appliquée au domaine Sécurité
Lors de l'audit de sécurité de Lizbiz's, trois questions du point de contrôle *Gestion des identifiants et des mots de passe* illustrent les trois modalités de réponse :

Question	Réponse	Interprétation
Existe-t-il une procédure de gestion des mots de passe ?	`N`	Défaillance avérée ; aucun document produit. Statut : `NON CONFORME`.
Les identifiants inutilisés sont-ils révoqués après un délai défini ?	`PAS`	L'administrateur réseau interrogé déclare qu'une procédure existe ń quelque part ż, mais ne peut en produire aucune trace. Statut : `ZONE GRISE`.
Vérifie-t-on qu'il y a un seul utilisateur par identifiant ?	`O`	Liste des comptes actifs produite ; vérification effectuée sans anomalie.
n		

L'entropie du point de contrôle sur ces trois questions est : $H = -\frac{1}{3}\log_2\frac{1}{3} - \frac{1}{3}\log_2\frac{1}{3} - \frac{1}{3}\log_2\frac{1}{3} \approx 1{,}585$ bits : valeur maximale, signalant que ce point de contrôle est une *zone grise critique*. La réponse PAS/NEK sur la révocation des identifiants n'indique pas que le contrôle est absent ; elle indique que l'organisation ne *sait pas* si elle le pratique, ce qui est, pour un auditeur, aussi préoccupant qu'une réponse N : un contrôle dont personne ne peut attester l'existence est un contrôle sur lequel on ne peut pas s'appuyer.

6.6 Protocole de construction de l'outil pour un nouveau domaine

La méthode de décomposition hiérarchique étant universelle, la construction de l'outil pour tout nouveau domaine d'audit suit un protocole en sept étapes.

6.6.1 Étape 1 : Délimiter le domaine

Définir précisément le périmètre de l'audit (application, fonction, projet, processus) et s'assurer que ce périmètre est formalisé dans la lettre de mission. Créer une nouvelle feuille dans le classeur et lui attribuer le nom codifié du domaine.

6.6.2 Étape 2 : Identifier les points de contrôle

À partir du référentiel applicable (guide d'audit IFACI/CIGREF, COBIT, ISO, ISACA ou référentiel sectoriel), lister les grands axes de vérification du domaine. Renseigner la colonne B. Vérifier que la liste est exhaustive (aucun axe majeur oublié), homogène (chaque axe couvre bien une composante distincte) et mutuellement exclusive (pas de recouvrement entre axes).

6.6.3 Étape 3 : Décomposer chaque point en objectifs de contrôle

Pour chaque point de contrôle, formuler les objectifs de contrôle correspondants en utilisant systématiquement les tournures *S'assurer que...* ou *Vérifier que...* Renseigner la colonne C. S'assurer que chaque objectif est un état attendu vérifiable, et non une action.

6.6.4 Étape 4 : Dériver les critères

Pour chaque objectif, décomposer l'état attendu en assertions élémentaires et vérifiables indépendamment l'une de l'autre. Renseigner la colonne D. Vérifier que la somme des critères est à la fois nécessaire et suffisante à l'objectif.

6.6.5 Étape 5 : Spécifier les éléments requis et les questions

Pour chaque critère : (i) identifier le document ou la preuve qui permettrait d'en établir la satisfaction (colonne E) ; (ii) reformuler le critère en question trichotomique (O / N / PAS) posable à l'audité (colonne F). Vérifier que la formulation est suffisamment précise pour qu'une réponse PAS/NEK soit distinguable d'une réponse N : si l'audité dit ń je ne sais pas ż, c'est un PAS ; si l'audité dit ń non, ça n'existe pas ż, c'est un N.

6.6.6 Étape 6 : Formuler les risques et les conséquences

Pour chaque question : (i) formuler l'état de non-conformité correspondant à une réponse négative (colonne H) ; (ii) décrire l'impact organisationnel de la réalisation de ce risque (colonne I). Évaluer la gravité de la conséquence et renseigner la pondération dans la plage nommée `GRAVITE`.

6.6.7 Étape 7 : Saisir les formules d'automatisation et tester

Implémenter les formules de statut (colonne K), de criticité (colonne J), de priorité (colonne M) et d'entropie de Shannon (colonne O, niveau point de contrôle). Appliquer les mises en forme conditionnelles : vert/rouge/orange ambré pour le statut, gradient blanc-jaune-rouge pour l'entropie. Relier la feuille à la feuille `SYNTHÈSE`. Effectuer un test en saisissant des réponses fictives couvrant les trois modalités (O, N, PAS) et vérifier que les calculs, les colorations, les scores d'entropie et les remontées en synthèse se comportent conformément aux spécifications.

Complétude de la décomposition

La décomposition d'un domaine $\mathcal{D}$ est dite *complète* si et seulement si les trois conditions suivantes sont simultanément satisfaites :

1. **Exhaustivité** : tout risque réel du domaine $\mathcal{D}$ est couvert par au moins une question d'évaluation de la grille ;
2. **Non-redondance** : aucune question n'est logiquement équivalente à une autre question de la même grille ;
3. **Traçabilité** : toute observation de terrain est rattachable, via la structure de

la grille, à un point de contrôle et à un objectif de contrôle précis.

Ces trois propriétés sont nécessaires et suffisantes pour garantir que le rapport d'audit produit à partir de l'outil est exhaustif, non redondant et opposable.

6.7 Le Tableau de Bord de Synthèse (Reporting)

L'outil ne doit pas être une simple liste de questions. Pour LiZbiZ, il doit générer une vision macroscopique.

- **Calcul du Taux de Conformité :** Moyenne pondérée des scores par domaine.
- **Visualisation :** Utilisation de graphiques de type "Radar" (Kiviat) pour identifier visuellement les faiblesses du SI.

Définition

Indicateur de Maturité : $M = \frac{\sum(Note \times Coeff)}{\sum Coeff}$.
Ce score permet de situer LiZbiZ sur une échelle de 0 à 5 (inspirée de l'échelle CMMI de COBIT).

partie III

Enjeux Contemporains et Évaluation

7

SUJETS CONNEXES : IA ET FRAUDE DANS LES SI

Au-delà des processus classiques, l'auditeur moderne doit adresser des défis technologiques et comportementaux nouveaux. Ce chapitre traite de l'impact de l'Intelligence Artificielle et de la fraude assistée par les systèmes d'information.

7.1 L'Intelligence Artificielle et l'Audit

L'IA est à la fois un sujet d'audit (l'entreprise utilise-t-elle l'IA correctement ?) et un outil pour l'auditeur (l'IA peut-elle m'aider à auditer ?).

7.1.1 Le Rôle et l'Impact de l'IA dans les SI

Les entreprises comme **Lizbiz's** intègrent l'IA pour optimiser leurs processus :

- **Automatisation :** Traitement des commandes, chatbots service client.
- **Prédictif :** Anticipation des stocks, analyse des risques financiers.

7.1.2 Les Risques Liés à l'IA

L'auditeur doit identifier les risques spécifiques à ces nouvelles technologies :

Type de Risque	Description
Biais Algorithmiques	L'IA prend des décisions discriminatoires basées sur des données biaisées (ex: refus de crédit injustifié).
Boîte Noire (Black Box)	Impossibilité d'expliquer comment l'IA a pris une décision (manque de traçabilité).
Sécurité des Données	L'IA a besoin de masses de données (Big Data), augmentant le risque de fuite.
Dépendance	L'entreprise perd le contrôle humain sur des processus critiques.

7.1.3 Enjeux pour l'Auditeur

Face à l'IA, l'auditeur doit adapter sa démarche :

1. **Auditer l'Algorithme :** Vérifier la qualité des données d'entrée (Garbage In, Garbage Out) et la pertinence du modèle.

2. **Vérifier l'Éthique :** S'assurer que les décisions de l'IA respectent la loi (RGPD) et l'éthique de l'entreprise.
3. **Utiliser l'IA :** L'auditeur peut utiliser des outils d'IA pour analyser des volumes de données impossibles à traiter manuellement (détection d'anomalies automatiques).

■ Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : L'entreprise utilise une IA pour gérer les stocks. L'auditeur constate que l'IA commande des stocks énormes pour des produits peu vendus. Analyse : Les données historiques utilisées pour "entraîner" l'IA contenaient des erreurs de saisie de l'année précédente. **Recommandation :** Nettoyer les données d'entraînement et mettre en place un contrôle humain avant validation des commandes fournisseurs.

7.2 La Fraude dans et par les Systèmes d'Information

Le SI est un terrain fertile pour la fraude : il centralise l'argent, les actifs et les données, tout en offrant une certaine anonymat technique.

7.2.1 Nature de la Fraude Informatique

La fraude peut prendre plusieurs formes :

- **Fraude Interne :** Complaisance, détournement de fonds, vol de données par un employé.
- **Fraude Externe :** Hameçonnage (Phishing), escroquerie au président, piratage.
- **Fraude aux Données :** Falsification des états financiers via le système comptable.

7.2.2 L'Impact de la Fraude

Les conséquences vont au-delà de la perte financière directe :

- **Perte d'Image :** Difficile à quantifier mais destructrice (perte de confiance clients).
- **Perte de Compétitivité :** Vol de secrets industriels ou de clientèle.
- **Coût de Remédiation :** Frais juridiques, amendes, reconstruction du SI.

7.2.3 Les Parades (Dispositifs Anti-Fraude)

L'auditeur vérifie l'existence et l'efficacité des dispositifs de prévention :

7.2.3.1 Contrôles Préventifs

- Séparation des tâches (la personne qui commande n'est pas celle qui paie).
- Gestion stricte des habilitations (Principe du moindre privilège).
- Sensibilisation des employés au Phishing.

7.2.3.2 Contrôles Détectifs

- Revue des logs et traces d'activité.
- Analyse de données (Data Mining) pour repérer des anomalies (ex: factures avec des montants ronds, doubles paiements).
- Ligne éthique (Whistleblowing) pour signaler les comportements suspects.

Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : Une rumeur de fraude circule sur la création de "Fournisseurs Fictifs". **Mission de l'Auditeur :** Utiliser des requêtes SQL sur la base de données fournisseurs pour identifier des anomalies :

- Fournisseurs créés récemment avec des montants énormes.
- Adresse du fournisseur identique à l'adresse d'un employé.
- Numéro de compte bancaire IBAN suspect.

L'analyse de données permet de détecter la fraude bien plus vite qu'un audit manuel papier.

7.2.4 Le Cadre Réglementaire : L'IA Act et la Classification des Risques

L'auditeur doit évaluer les systèmes d'IA de l'entreprise (comme les outils de prédiction de stocks de **LiZbiZ**) au regard des nouvelles réglementations internationales. L'approche est basée sur le niveau de risque :

Risque Inacceptable : Systèmes interdits (ex: notation sociale, surveillance biométrique en temps réel).

Haut Risque : Systèmes impactant la sécurité ou les droits fondamentaux (ex: recrutement automatisé, gestion des infrastructures critiques). *Audit obligatoire.*

Risque Limité : Obligations de transparence (ex: Chatbots, Deepfakes). L'utilisateur doit savoir qu'il interagit avec une IA.

Risque Minime : Aucune obligation particulière (ex: filtres anti-spam).

7.3 L'Audit Forensics : De la Constatation à la Preuve Judiciaire

Lorsque l'auditeur identifie une fraude, la mission bascule dans une phase d'investigation numérique (*Digital Forensics*). L'objectif n'est plus seulement l'amélioration, mais la manifestation de la vérité.

7.3.1 La Chaîne de Garde (Chain of Custody)

Pour qu'une preuve soit admissible, l'auditeur doit documenter de manière ininterrompue qui a manipulé l'élément de preuve, où et quand.

7.3.2 Principes de Saisie de Preuve Numérique

L'auditeur doit suivre une méthodologie stricte pour ne pas polluer les traces :

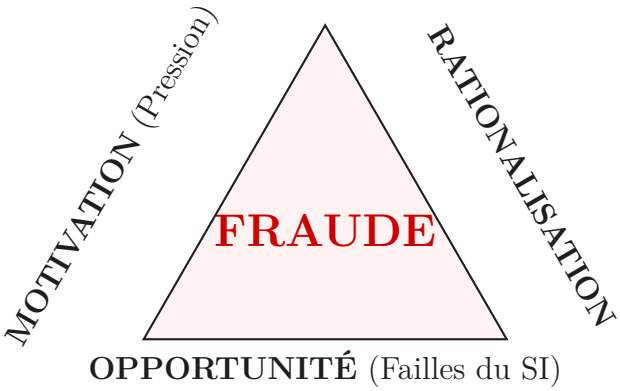
1. **Collecte de la volatilité :** Capturer la mémoire vive (RAM) avant d'éteindre la machine (car elle contient les clés de chiffrement et connexions actives).
2. **Duplication bit-à-bit :** Utilisation de bloqueurs d'écriture matériels pour créer une image miroir des supports (Disques durs, clés USB).
3. **Calcul d'empreinte (Hash) :** Utilisation d'algorithmes (SHA-256) pour garantir l'intégrité de la copie.

★ Attention

Conseil de l'Expert : Ne travaillez jamais sur l'original. Toute analyse doit être effectuée sur une copie certifiée conforme.

7.3.3 Schématisation : Le Triangle de la Fraude

L'auditeur doit comprendre les trois facteurs qui poussent un individu (par exemple un employé de **LiZbiZ**) à passer à l'acte.



8

ÉVALUATION FINALE DU COURS

Cette évaluation valide l'acquisition des concepts fondamentaux de l'audit, la maîtrise de la démarche méthodologique et la connaissance des référentiels.

8.1 Partie A : QCM (Choix Multiples)

Consigne : Cochez la ou les bonnes réponses.

Chapitre 2 : Fondamentaux

1. L'audit a pour sujet principal :

A. Une opération unitaire.
B. Un processus global.
C. Un employé précis.
D. Une transaction financière.

2. Le "Risque Résiduel" est :

A. Le risque avant toute mesure de sécurité.
B. Le risque qui reste après l'application des contrôles.
C. Un risque qui ne peut pas se produire.
D. Le risque de l'auditeur de se tromper.

3. La règle des "Quatre Yeux" signifie :

A. Avoir quatre yeux (mutation génétique).
B. Qu'une opération sensible doit être validée par deux personnes distinctes.
C. Relire un document quatre fois.
D. Avoir deux superviseurs.

4. Un contrôle "Préventif" a pour but de :

A. Détecter l'erreur après coup.
B. Empêcher l'erreur ou la fraude de se produire.
C. Coriger l'erreur.
D. Sanctionner le coupable.

5. L'assurance fournie par un audit est dite "Raisonnable" car :

A. L'auditeur est gentil.

B. Elle n'est pas absolue (limites de l'échantillonnage et du temps).

C. Elle est garantie à 100%.

D. Elle dépend du prix payé.

Chapitre 3 : Démarche et Normes

6. La norme qui encadre la méthodologie de l'audit est :

A. ISO 27001.

B. ISO 19011.

C. COBIT.

D. COSO.

7. Le principe de "Confidentialité" pour l'auditeur signifie :

A. Ne rien dire à personne.

B. Protéger les informations sensibles découvertes.

C. Cacher les résultats à la direction.

D. Signer un accord de non-divulgation.

8. Le "Rapport d'Orientation" est validé par :

A. L'auditeur.

B. L'audité.

C. Le Commanditaire (PDG/COMEX).

D. Le fournisseur informatique.

9. La phase de "Contradictoire" permet à l'audité de :

A. Contester les observations et apporter des preuves nouvelles.

B. Refuser le rapport.

C. Corriger lui-même ses erreurs.

D. Changer l'auditeur.

10. Une observation d'audit contient obligatoirement :

A. Le nom du coupable.

B. Le risque, la cause et le constat.

C. Une amende.

D. Une opinion personnelle.

Chapitre 4 : Référentiels

11. COSO est un modèle de :

A. Sécurité réseau.
B. Contrôle Interne.
C. Développement logiciel.
D. Gestion de projet.

12. COBIT est un référentiel pour :

A. La gouvernance et le management des SI.
B. La comptabilité.
C. La sécurité physique.
D. Les ressources humaines.

13. La norme certifiable pour la sécurité de l'information est :

A. ISO 27002.
B. ISO 27001.
C. ISO 27005.
D. ISO 19011.

14. Le domaine COBIT "Acquérir et Implémenter" concerne :

A. L'exploitation quotidienne.
B. Les projets et changements.
C. La stratégie.
D. Le budget.

15. Les 5 composantes de COSO incluent :

A. L'environnement de contrôle.
B. La gestion des stocks.
C. Le marketing.
D. La paie.

Chapitre 5 : Types d'Audits

16. L'audit d'une application en service vérifie :

A. La fiabilité et la sécurité des données.
B. Le projet de développement.
C. Les contrats des fournisseurs.

D. L'organigramme de l'entreprise.

17. Les "Contrôles Généraux" (General Controls) portent sur :

A. Une fonction précise du logiciel.
B. L'environnement global (OS, Réseau, Sauvegarde).
C. Une facture spécifique.
D. Un utilisateur unique.

18. L'audit de sécurité vérifie le principe DIC/T. La lettre I signifie :

A. Informatique.
B. Intégrité.
C. Intelligence.
D. Investissement.

19. L'audit de projet intervient généralement :

A. Uniquement après la panne.
B. Pendant le projet (jalons) ou à la fin.
C. Avant le cahier des charges.
D. Jamais.

20. Un "Pentest" (Test d'intrusion) est :

A. Un audit de configuration.
B. Une simulation d'attaque réelle.
C. Une réunion de travail.
D. Un test de performance.

Chapitre 6 : Sujets Connexes

21. Le risque principal de l'utilisation de l'IA pour l'auditeur est :

A. L'automatisation.
B. Le biais algorithmique et la "boîte noire".
C. Le coût élevé.
D. La rapidité.

22. La fraude "interne" est commise par :

A. Un concurrent.
B. Un employé de l'entreprise.
C. Un client.

D. Un hacker étranger.

23. La "Séparation des Tâches" est un contrôle :

A. Correctif.
B. Détectif.
C. Préventif.
D. Technique.

24. Pour détecter une fraude, l'auditeur utilise souvent :

A. L'intuition.
B. L'analyse de données (Data Mining).
C. Les rumeurs.
D. La voyance.

25. La ligne éthique (Whistleblowing) sert à :

A. Signaler anonymement des comportements suspects.
B. Commander du matériel.
C. Gérer les mots de passe.
D. Contacter le support.

8.2 Partie B : Vrai ou Faux

Consigne : Justifiez si faux (optionnel).

1. L'auditeur interne est obligatoirement un employé de l'entreprise. **(Vrai)**
2. Un contrôle détectif empêche la fraude de se produire. **(Faux - Il la détecte après coup)**
3. L'indépendance est un principe éthique obligatoire pour l'auditeur. **(Vrai)**
4. Le rapport d'audit est la seule production de l'auditeur. **(Faux - Il y a les papiers de travail, le rapport d'orientation...)**
5. COSO est un référentiel réservé à l'informatique. **(Faux - C'est un modèle de contrôle interne généraliste)**
6. ISO 27002 contient les exigences de certification. **(Faux - C'est ISO 27001, l'ISO 27002 est un guide de bonnes pratiques)**
7. L'audit d'application vérifie uniquement le code source. **(Faux - Il vérifie les données, les processus et l'environnement)**
8. Le "Suivi d'audit" (Follow-up) sert à vérifier l'application des recommandations. **(Vrai)**

9. L'IA peut être utilisée comme outil d'aide à l'audit. **(Vrai)**
10. Le principe de "Présentation équitable" permet à l'auditeur de mentir pour protéger l'entreprise. **(Faux - Il doit être honnête et factuel)**

8.3 Partie C : Questions Ouvertes

Consigne : Répondez en 10-15 lignes.

1. Expliquez la différence fondamentale entre l'Approche fondée sur les risques et l'Approche fondée sur les contrôles en audit.
2. Quels sont les 5 composantes du référentiel COSO et quel est leur lien ?
3. Décrivez les 3 phases principales de la relation avec l'audité lors d'une mission (Ouverture, Terrain, Clôture).
4. Pourquoi la "Charte d'Audit" est-elle un document indispensable pour l'auditeur interne ?
5. Comparez les objectifs d'un "Audit de Sécurité" et d'un "Audit de Performance".
6. Quels sont les risques spécifiques liés à l'intégration de l'Intelligence Artificielle dans les SI que l'auditeur doit vérifier ?
7. Expliquez le principe de séparation des tâches (Règle des deux mains) avec un exemple concret.

8.4 Partie D : Cas Pratique (Étude de Cas)

8.4.1 Scénario : Audit de l'Application "Comptabilité" de Lizbiz's

Vous êtes l'auditeur senior mandaté pour auditer le module comptabilité de l'APPLICATION de Lizbiz's. Lors de vos tests, vous constatez les faits suivants :

1. L'administrateur système "Root" a accès directement à la base de données financières sans passer par l'application.
2. Les sauvegardes journalières sont stockées sur un disque dur USB posé sur le bureau du comptable.
3. Le comptable principal part en vacances et donne son mot de passe à son stagiaire pour qu'il continue le travail.

Travaux demandés :

1. Pour chaque fait constaté, identifiez :
   - ➢ Le risque encouru par Lizbiz's.
   - ➢ Le type de contrôle défaillant (Préventif, Détectif, organisationnel, technique).

2. Rédigez une recommandation appropriée pour le constat nř3 (Partage de mot de passe).
3. En vous référant à ISO 27001, citez un domaine de l'Annexe A qui aurait permis d'éviter le constat nř2 (Sauvegardes).

partie IV

Travaux Pratiques Immersifs

9

LABORATOIRE 1 : AUDIT D'UNE APPLICATION EN SERVICE

Ce laboratoire met en pratique la méthodologie d'audit sur le cas de l'application comptable de l'entreprise LiZbiZ, nommée **APPLICATION**. L'objectif est de simuler une mission réelle : revue de contrôle interne, tests de données et rédaction de rapport.

9.1 Objectifs du TP

- Créer et peupler l'environnement technique (Base de données).
- Concevoir les outils d'audit (Grilles de contrôle).
- Réaliser des tests de contrôles et des tests substantifs via SQL.
- Rédiger le rapport d'audit final.

9.2 Étape 1 : Préparation de l'Environnement (Base de Données)

Avant d'auditer, il faut disposer du système. Nous allons créer le schéma de la base de données de l'APPLICATION.

9.2.1 Création du Schéma Relationnel

Exécutez le script SQL suivant sur votre SGBD (PostgreSQL ou MySQL).

```sql
-- Creation des tables

CREATE TABLE UTILISATEUR (
    IdUser INT PRIMARY KEY,
    Nom VARCHAR(50),
    Prenom VARCHAR(50),
    Service VARCHAR(50),
    Profil VARCHAR(20), -- 'Admin', 'Comptable', 'Validation'
    Actif BOOLEAN
);

CREATE TABLE JOURNAL (
    CodeJournal VARCHAR(5) PRIMARY KEY,
    Libelle VARCHAR(50)
);

CREATE TABLE COMPTE (
```

```sql
    NumCompte VARCHAR(10) PRIMARY KEY,
    Libelle VARCHAR(100),
    Classe VARCHAR(2)
);

CREATE TABLE TIERS (
    IdTiers INT PRIMARY KEY,
    Nom VARCHAR(100),
    Type VARCHAR(20), -- 'Client', 'Fournisseur'
    Email VARCHAR(100)
);

CREATE TABLE ECRITURE (
    IdEcriture INT PRIMARY KEY,
    DateEcriture DATE,
    CodeJournal VARCHAR(5),
    NumCompte VARCHAR(10),
    IdTiers INT,
    Libelle VARCHAR(200),
    Debit DECIMAL(15,2),
    Credit DECIMAL(15,2),
    IdUserCreate INT,
    IdUserValid INT, -- Utilisateur qui valide
    Statut VARCHAR(10), -- 'Brouillon', 'Valide'
    FOREIGN KEY (CodeJournal) REFERENCES JOURNAL(CodeJournal),
    FOREIGN KEY (NumCompte) REFERENCES COMPTE(NumCompte),
    FOREIGN KEY (IdTiers) REFERENCES TIERS(IdTiers)
);
```

Listing 9.1: Script de création de la base APPLICATION

9.2.2 Chargement des Données de Test

Insérez un jeu de données fictives pour simuler l'activité de LiZbiZ. (Voir annexe du PDF source pour un jeu complet ou générez-en un simplifié).

```sql
-- Insertion des utilisateurs
INSERT INTO UTILISATEUR VALUES (1, 'DUPONT', 'Marie', 'Comptabilite'
    , 'Comptable', TRUE);
INSERT INTO UTILISATEUR VALUES (2, 'MARTIN', 'Paul', 'Direction', '
    Validation', TRUE);
INSERT INTO UTILISATEUR VALUES (3, 'HACK', 'Bad', 'IT', 'Admin',
    TRUE);

-- Insertion d'une ecriture suspecte (Fraude potentielle)
INSERT INTO ECRITURE VALUES (1001, '2023-12-15', 'ACH', '607', 50, '
    Achat Fictif', 5000, 0, 1, 1, 'Valide');
```

Listing 9.2: Exemple d'insertion

9.3 Étape 2 : Évaluation du Contrôle Interne (COSO)

L'objectif est de concevoir la "Checklist" d'audit.

9.3.1 Domaine : Environnement de Contrôle

Concevez un questionnaire d'évaluation pour vérifier la culture sécurité du service comptabilité de LiZbiZ. **Questions à formuler :**

- Existe-t-il une charte informatique signée par les comptables ?
- Les utilisateurs connaissent-ils leur profil d'accès ?
- Qui a le profil "Admin" sur l'application ?

9.3.2 Domaine : Activités de Contrôle (Séparation des Tâches)

C'est le point critique. Vérifiez la matrice RACI. **Tâche :** Vérifier si un même utilisateur peut créer ET valider une écriture (Risque de fraude majeur).

Cas Pratique — Entreprise LiZbiZ

Requête SQL de vérification (Audit Technique) : Ecrire une requête pour détecter les utilisateurs qui ont créé une écriture et l'ont eux-mêmes validée.

```sql
SELECT IdEcriture, Libelle, IdUserCreate
FROM ECRITURE
WHERE IdUserCreate = IdUserValid;
```

Analyse : Si le résultat n'est pas vide, c'est une Non-Conformité Majeure (Règle des 4 yeux non respectée).

9.4 Étape 3 : Audit des Données (Tests Substantifs)

Nous utilisons le langage SQL comme outil d'audit (CAATs - Computer Assisted Audit Techniques).

9.4.1 Test d'Intégrité : Recherche de Doublons

Risque : Factures payées deux fois. **Objectif :** Détecter les écritures strictement identiques (même montant, même date, même tiers, même libellé).

```sql
SELECT DateEcriture, IdTiers, Libelle, Sum(Debit) as TotalDebit,
    Count(*) as NbOcurrences
FROM ECRITURE
GROUP BY DateEcriture, IdTiers, Libelle
HAVING Count(*) > 1;
```

9.4.2 Test de Cohérence : Equilibre Journal

Risque : Déséquilibre comptable. **Objectif :** Vérifier que Total Débit = Total Crédit pour chaque journal.

```sql
SELECT CodeJournal, SUM(Debit) as TotalD, SUM(Credit) as TotalC
FROM ECRITURE
GROUP BY CodeJournal
HAVING SUM(Debit) != SUM(Credit);
```

9.4.3 Test de Convention : Seuil de Validation

Règle de gestion LiZbiZ : Toute écriture supérieure à 5000 doit être validée par le Directeur (Profil 'Validation'). **Objectif :** Détecter les écritures > 5000 validées par un simple comptable.

```sql
SELECT E.IdEcriture, E.Libelle, E.Debit, U.Nom as Validateur, U.
    Profil
FROM ECRITURE E
JOIN UTILISATEUR U ON E.IdUserValid = U.IdUser
WHERE E.Debit > 5000 AND U.Profil != 'Validation';
```

9.5 Étape 4 : Rapport d'Audit

9.5.1 Rédaction des Observations

Sur la base des requêtes exécutées, rédigez une fiche d'observation pour le rapport final (Format : Constat / Risque / Recommandation).

Exemple de fiche à compléter :

Titre	Non respect de la séparation des tâches (Création/Validation).
Constat	La requête SQL a identifié X écritures validées par leur créateur.
Risque	Fraude interne sans contrôle (Détournement possible).
Recommandation	Configurer l'APPLICATION pour interdire l'auto-validation (Bloquer l'enregistrement si IdUserCreate = IdUserValid).

Table 9.1: Modèle de fiche d'observation

9.6 Livrables à rendre

1. Le script SQL de création de la base (Fichier .sql).
2. Le fichier Excel ou Word contenant les grilles de contrôle interne.
3. Les scripts SQL utilisés pour les tests (Audit des données).
4. Le rapport d'audit final (PDF) contenant les observations et le plan d'action.

10

LABORATOIRE 2 : AUDIT DE SÉCURITÉ D'UNE INFRASTRUCTURE

Ce laboratoire complète l'audit fonctionnel par une approche technique. L'objectif est d'évaluer la sécurité du réseau et des systèmes de l'entreprise LiZbiZ pour détecter les vulnérabilités exploitables par un attaquant.

10.1 Objectifs du TP

- Analyser une architecture réseau pour valider la segmentation.
- Réaliser un audit de configuration (pare-feu, services).
- Utiliser des outils d'audit standards (Nmap, scanners de vulnérabilités).
- Produire un rapport technique d'audit infrastructure.

10.2 Étape 1 : Analyse de l'Architecture (Revue Documentaire)

10.2.1 Présentation de l'Infrastructure LiZbiZ

L'infrastructure cible est modélisée sous GNS3 ou EVE-NG. Elle est composée de trois zones principales :

- **VLAN 10 (DMZ) :** Serveur Web Public (Accessibilité Internet).
- **VLAN 20 (Applicatif) :** Serveur ERP, Base de Données.
- **VLAN 30 (Utilisateurs) :** Postes de travail, Active Directory.

10.2.2 Travail Demandé : Analyse de la Cartographie

À partir du schéma fourni (ou de la simulation), répondez aux questions suivantes :

1. Le serveur Web en DMZ a-t-il un accès direct au VLAN Utilisateurs ? (Risque : pivot depuis le web vers les postes).
2. La Base de Données est-elle accessible depuis Internet ? (Risque : exposition des données).
3. Les protocoles d'administration (SSH, Telnet, RDP) sont-ils autorisés entre toutes les zones ?

★ Attention

Attention : Une architecture correcte doit interdire tout flux direct Internet → BDD. Le flux doit passer par le Serveur Web (Proxy).

10.3 Étape 2 : Découverte et Cartographie Réelle (Nmap)

L'auditeur ne se fie pas uniquement aux schémas théoriques. Il doit scanner le réseau pour voir la réalité technique ("Shadow IT" potentiel).

10.3.1 Scan de Découverte

Utilisez l'outil **Nmap** depuis une machine attaquante (ex: Kali Linux) placée en position externe (simulant Internet) ou interne (simulant un poste utilisateur compromis).

Commande de base :

```
# Scan rapide pour voir les hotes actifs
nmap -sn 192.168.1.0/24

# Scan des ports ouverts sur le serveur Web
nmap -sV -p- 192.168.1.10 (IP Serveur Web)
```

Listing 10.1: Scan réseau Nmap

10.3.2 Questions d'Audit

- **Question 1 :** Quels ports sont ouverts sur le serveur Web ? (Attendu : 80/443. Risque : 22, 21, 3389 ouverts).
- **Question 2 :** Le pare-feu bloque-t-il les pings (ICMP) ? (Mesure de sécurité basique).
- **Question 3 :** Identifiez-vous des services vulnérables (ex: FTP non chiffré, vieux Apache) ?

10.4 Étape 3 : Audit de Configuration et Vulnérabilités

10.4.1 Test de Segmentation (Bypass Pare-feu)

Objectif : Vérifier que le VLAN Utilisateur ne peut pas accéder directement au port d'administration de la Base de Données (ex: port 3306 ou 5432).

Action : Depuis une machine du VLAN 30, tentez de vous connecter au port SQL du VLAN 20.

```
telnet <IP_SERVEUR_DB> 3306
# Si la connexion s'ouvre -> ECHEC DU CONTROLE (Segmentation
    inexistante).
```

10.4.2 Scan de Vulnérabilités (OpenVAS / Nessus)

Lancez un scan de vulnérabilités sur le serveur Web (DMZ). **Analyse des résultats :**

- Classez les vulnérabilités par sévérité (Critical, High, Medium).
- Identifiez les failles connues (CVE) non patchées.

Cas Pratique — Entreprise LiZbiZ

Cas Lizbiz's : Le scan révèle que le serveur Web exécute une version d'Apache datant de 2018 (CVE critique présente). **Constat :** Le processus de mise à jour (Patch Management) est défaillant. **Risque :** Prise de contrôle totale du serveur par un attaquant externe.

10.5 Étape 4 : Analyse des Configurations (Hardening)

10.5.1 Audit des Comptes par Défaut

Connectez-vous aux équipements (Routeur/Firewall) ou aux services (Base de données). Vérifiez :

- Est-ce que le compte "admin" / "admin" fonctionne encore ?
- Est-ce que le compte "root" de la base de données a un mot de passe vide ?

10.5.2 Audit des Protocoles

Service	Configuration Sécurisée	Configuration Observée
Administration Réseau	SSH (v2)	Telnet (Clair) ?
Transfert Fichier	SFTP / SCP	FTP (Clair) ?
Accès Web	HTTPS	HTTP ?

Table 10.1: Grille de vérification des protocoles

10.6 Étape 5 : Rapport d'Audit Technique

10.6.1 Synthèse des Risques

Résumez les risques majeurs identifiés (Impact Technique → Impact Métier).

10.6.2 Plan de Remédiation

Proposez un plan d'action technique pour LiZbiZ (Exemples : "Fermer le port 22 sur la DMZ", "Migrer de HTTP à HTTPS", "Appliquer les mises à jour de sécurité").

10.7 Livrables à Rendre

1. Fichier Nmap (format XML ou texte) montrant les résultats du scan.
2. Tableau d'analyse de la segmentation (Matrice de flux autorisés vs observés).
3. Rapport d'audit technique avec classification des vulnérabilités (CVSS).

CONCLUSION GÉNÉRALE

« L'audit est terminé lorsque le dernier doute raisonnable a été levé, documenté et communiqué. »
— Principe fondateur de l'IIA

Ce que Vous Avez Appris

Au terme de ce parcours, vous avez traversé l'intégralité du spectre de l'audit des systèmes d'information — des fondements conceptuels aux tests techniques, du vocabulaire professionnel à la rédaction du rapport final. Ce cheminement n'était pas linéaire dans sa nature : il était *spiralaire*, chaque niveau de compréhension enrichissant rétrospectivement les acquis antérieurs.

Vous avez appris à distinguer ce que l'on **contrôle** de ce que l'on **audite**, à mesurer un **risque résiduel** plutôt qu'à fantasmer un risque zéro, à lire un SI non comme une boîte noire mais comme un *système de contrôles imbriqués* dont la solidité se mesure au maillon le plus faible.

Vous avez découvert que l'auditeur moderne n'est pas seulement un expert technique : il est un **traducteur** entre le monde de la machine et celui de la décision stratégique, capable de transformer des lignes de logs en recommandations compréhensibles par un comité de direction.

Synthèse des Compétences Acquises

★ À retenir

Les compétences fondamentales consolidées au cours de cette formation :

1. **Maîtrise du cadre conceptuel :** Distinction audit / contrôle, assurance raisonnable, cycle du risque, contrôle interne (COSO).
2. **Connaissance des référentiels :** COBIT, ISO 27001/27002, ISO 19011 comme grilles d'évaluation universelles.
3. **Conduite d'une mission :** Planification, exécution (tests documentaires, entretiens, tests techniques), rédaction du rapport contradictoire.
4. **Audit technique :** Requêtes SQL d'analyse de données, scan réseau (Nmap), audit de configuration, détection de vulnérabilités.
5. **Enjeux émergents :** Gouvernance de l'IA, détection de la fraude numérique, protection des données personnelles (RGPD).

6. **Communication professionnelle :** Rédaction de constats, d'observations et de plans d'action à destination de la direction générale.

Le Cas LiZbiZ : Bilan de la Mission

L'entreprise LiZbiZ a constitué tout au long de ce cours le terrain d'application de votre apprentissage. À travers elle, vous avez rencontré des situations que tout auditeur croisera inévitablement dans sa carrière : une application comptable dont la piste d'audit était défaillante, une infrastructure réseau mal segmentée exposant la base de données, un projet d'IA dont les données d'entraînement étaient contaminées, des rumeurs de fraude aux fournisseurs fictifs transformées en constats documentés.

Cas Pratique — Entreprise LiZbiZ

Bilan de la mission LiZbiZ :

- **Observations critiques identifiées :** Absence de piste d'audit sur le module comptable ; segmentation réseau inefficace ; serveur Apache non patché (CVE critique) ; présence de comptes fournisseurs suspects.
- **Niveau de risque résiduel global :** **Élevé** — justifiant un suivi de recommandations à 30, 90 et 180 jours.
- **Recommandation principale :** Mise en place d'un programme de contrôle interne continu (COSO Pilotage) et certification ISO 27001 à 18 mois.

Perspectives Professionnelles

L'audit des SI est l'une des disciplines dont la demande ne cesse de croître à mesure que la transformation numérique s'accélère. Les certifications CISA (*Certified Information Systems Auditor*), CISM (*Certified Information Security Manager*) et CRISC (*Certified in Risk and Information Systems Control*), délivrées par l'ISACA, constituent les références mondiales du secteur. Elles ouvrent les portes des cabinets d'audit des quatre plus grands (Deloitte, PwC, EY, KPMG), des institutions publiques de contrôle supérieur, et des directions d'audit interne des grandes organisations.

Note

Pour aller plus loin :

- *ISACA — CISA Review Manual*, édition courante.
- *IIA — International Standards for the Professional Practice of Internal Auditing.*
- *ISO/IEC 27001:2022 — Systèmes de management de la sécurité de l'information.*
- *NIST Cybersecurity Framework* (v2.0, 2024).

➢ Revue *ISACA Journal* — articles pratiques et cas d'études sectoriels.

Mot Final

L'audit n'est pas une fin en soi. C'est un instrument au service d'une ambition plus haute : permettre aux organisations d'apprendre d'elles-mêmes, de se corriger avec lucidité et de construire une confiance durable avec leurs parties prenantes. Dans un monde où l'information est la ressource la plus précieuse et la plus vulnérable à la fois, l'auditeur SI est, plus que jamais, un gardien de la confiance numérique.

Que vous exerciez demain en cabinet, en institution publique ou au sein d'une direction de l'audit interne, portez cette conviction : *un constat bien documenté vaut mieux qu'une intuition brillante.* La rigueur est votre crédibilité. L'indépendance, votre autorité.

Rédigé et enseigné avec la conviction que la maîtrise du numérique est une responsabilité collective autant qu'individuelle.

MINKA MI NGUIDJOÏ Thierry Emmanuel

Université de Yaoundé I — ENSPY — 2025–2026

À propos de ce cours

Ce cours propose une approche intégrée et rigoureuse de l'audit des systèmes d'information, articulant les fondements théoriques du contrôle interne, les référentiels internationaux reconnus (COSO, COBIT, ISO 27001) et une pratique immersive à travers le cas fil rouge de l'entreprise LiZbiZ.

Il s'adresse aux étudiants en informatique, gestion et sécurité des SI souhaitant acquérir les compétences opérationnelles et conceptuelles requises pour conduire des missions d'audit avec professionnalisme, en conformité avec les standards de l'ISACA et de l'IIA.

Les thèmes abordés couvrent la démarche d'audit, l'analyse des risques, les tests fonctionnels et techniques, la gouvernance de l'intelligence artificielle, la détection de la fraude et la rédaction du rapport final.

MINKA MI NGUIDJOÏ Thierry Emmanuel

CISA ů CISM ů CGEIT ů CRISC ů CDPSE

Chercheur — LIMSI, Université de Yaoundé I ů Cameroun